

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

How to read the report | Suppressing false positives | Getting Help: github issues

Sponsor

Project: rest-service

com.twk:rest-service:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 12.1.0
- *Report Generated On*: Tue, 15 Sep 2026 11:32:25 -0400
- *Dependencies Scanned*: 38 (23 unique)
- *Vulnerable Dependencies*: 13
- *Vulnerabilities Found*: 293
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency↑	Vulnerability IDs	Package	Highest Severity	CVE Coun
bcprov-jdk15on-1.46.jar	cpe:2.3:a:bouncycastle:bouncy-castle-crypto-package:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:bouncy_castle_crypto_package:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:bouncy_castle_for_java:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:legion-of-the-bouncy-castle-java-crytography-api:1.46:*:*:*:*:*:*:* cpe:2.3:a:bouncycastle:the_bouncy_castle_crypto_package_for_java:1.46:*:*:*:*:*:*:*	pkg:maven/org.bouncycastle/bcprov-jdk15on@1.46	HIGH	4
hibernate-validator-6.0.18.Final.jar	cpe:2.3:a:hibernate:hibernate-validator:6.0.18:*:*:*:*:*:*:* cpe:2.3:a:redhat:hibernate_validator:6.0.18:*:*:*:*:*:*:* cpe:2.3:a:validator:validator:6.0.18:*:*:*:*:*:*:*	pkg:maven/org.hibernate.validator/hibernate-validator@6.0.18.Final	MEDIUM	4
jackson-databind-2.10.2.jar	cpe:2.3:a:fasterxml:jackson-core:2.10.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-databind:2.10.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.10.2:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.10.2	HIGH	11
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	MEDIUM	5
logback-core-1.2.3.jar	cpe:2.3:a:qos:logback:1.2.3:*:*:*:*:*:*:*	pkg:maven/ch.qos.logback/logback-core@1.2.3	HIGH	2
snakeyaml-1.25.jar	cpe:2.3:a:snakeyaml_project:snakeyaml:1.25:*:*:*:*:*:*:*	pkg:maven/org.yaml/snakeyaml@1.25	CRITICAL	8
spring-boot-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot@2.2.4.RELEASE	CRITICAL	9
spring-boot-starter-web-2.2.4.RELEASE.jar	cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:* cpe:2.3:a:web_project:web:2.2.4:release:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE	CRITICAL	9
spring-core-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@5.2.3.RELEASE	CRITICAL*	29
spring-web-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:web_project:web:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@5.2.3.RELEASE	CRITICAL*	30
spring-webmvc-5.2.3.RELEASE.jar	cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:* cpe:2.3:a:web_project:web:5.2.3:release:*:*:*:*:*:*	pkg:maven/org.springframework/spring-webmvc@5.2.3.RELEASE	CRITICAL*	29
tomcat-embed-core-9.0.30.jar	cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:9.0.30:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@9.0.30	CRITICAL*	76
tomcat-embed-websocket-9.0.30.jar	cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:9.0.30:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-websocket@9.0.30	CRITICAL*	77

* indicates the dependency has a known exploited vulnerability

Dependencies (vulnerable)

bcprov-jdk15on-1.46.jar

Description:

The Bouncy Castle Crypto package is a Java implementation of cryptographic algorithms. This jar contains JCE provider and lightweight API for the Bouncy Castle Cryptography APIs for JDK 1.5 to JDK 1.7.

License:

Bouncy Castle Licence: http://www.bouncycastle.org/licence.html

File Path: C:\Users\Grace School\.m2\repository\org\bouncycastle\bcprov-jdk15on\1.46\bcprov-jdk15on-1.46.jar
MD5: b94e6fef30e871f1b4117232cdc75369
SHA1: 991c96a4e31e6c19e2b9136c8955bd423f2dc4c7
SHA256:a1952237d941ef0b6122ba27b0b58de602de91c714ba3ddd4eef30ba3f5a0a67
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/com.twk/rest-service@0.0.1-SNAPSHOT

Evidence

Identifiers

- pkg:maven/org.bouncycastle/bcprov-jdk15on@1.46 (*Confidence*:High)
- cpe:2.3:a:bouncycastle:bouncy-castle-crypto-package:1.46:*:*:*:*:*:*:* (*Confidence*:Low) suppress
- cpe:2.3:a:bouncycastle:bouncy_castle_crypto_package:1.46:*:*:*:*:*:*:* (*Confidence*:Low) suppress
- cpe:2.3:a:bouncycastle:bouncy_castle_for_java:1.46:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:bouncycastle:legion-of-the-bouncy-castle-java-crytography-api:1.46:*:*:*:*:*:*:* (*Confidence*:Low) suppress
- cpe:2.3:a:bouncycastle:the_bouncy_castle_crypto_package_for_java:1.46:*:*:*:*:*:*:* (*Confidence*:Low) suppress

Published Vulnerabilities

CVE-2016-1000338 suppress

In Bouncy Castle JCE Provider version 1.55 and earlier the DSA does not fully validate ASN.1 encoding of signature on verification. It is possible to inject extra elements in the sequence making up the signature and still have it validate, which in some cases may allow the introduction of 'invisible' data into a signed structure.

CWE-347 Improper Verification of Cryptographic Signature

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:bouncycastle:legion-of-the-bouncy-castle-java-crytography-api:*:*:*:*:*:*:*:* versions from (including) 1.38; versions up to (excluding) 1.56
- ...

CVE-2020-15522 suppress

Bouncy Castle BC Java before 1.66, BC C# .NET before 1.8.7, BC-FJA before 1.0.1.2, 1.0.2.1, and BC-FNA before 1.0.1.1 have a timing issue within the EC math library that can expose information about the private key when an attacker is able to observe timing information for the generation of multiple deterministic ECDSA signatures.

CWE-362 Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY

- cve@mitre.org - RELEASE_NOTES,VENDOR_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:bouncycastle:the_bouncy_castle_crypto_package_for_java:*:*:*:*:*:*:*:* versions up to (excluding) 1.66
- ...

CVE-2023-33202 suppress

Bouncy Castle for Java before 1.73 contains a potential Denial of Service (DoS) issue within the Bouncy Castle org.bouncycastle.openssl.PEMParser class. This class parses OpenSSL PEM encoded streams containing X.509 certificates, PKCS8 encoded keys, and PKCS7 objects. Parsing a file that has crafted ASN.1 data through the PEMParser causes an OutOfMemoryError, which can enable a denial of service attack. (For users of the FIPS Java API: BC-FJA 1.0.2.3 and earlier are affected; BC-FJA 1.0.2.4 is fixed.)

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (5.5)
- Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H/E:1.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRODUCT
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRODUCT
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:bouncycastle:bouncy_castle_for_java:*:*:*:*:*:*:*:* versions up to (excluding) 1.73
- ...

CVE-2015-7940 suppress

The Bouncy Castle Java library before 1.51 does not validate a point is withing the elliptic curve, which makes it easier for remote attackers to obtain private keys via a series of crafted elliptic curve Diffie Hellman (ECDH) key exchanges, aka an "invalid curve attack."

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor, CWE-310 Cryptographic Issues

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - TECHNICAL_DESCRIPTION
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- cve@mitre.org - TECHNICAL_DESCRIPTION
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY,VDB_ENTRY
- cve@mitre.org - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:bouncycastle:bouncy_castle_crypto_package:*:*:*:*:*:*:*:* versions up to (including) 1.50
- ...

hibernate-validator-6.0.18.Final.jar

Description:

Hibernate's Bean Validation (JSR-380) reference implementation.

License:

http://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\org\hibernate\validator\hibernate-validator\6.0.18.Final\hibernate-validator-6.0.18.Final.jar
MD5: d3eeb4f1bf013d939b86dfc34b0c6a5d
SHA1: 7fd00bcd87e14b6ba66279282ef15efa30dd2492
SHA256:79fb11445bc48e1ea6fb259e825d58b3c9a5fa2b7e3c9527e41e4aeda82de907
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.hibernate.validator/hibernate-validator@6.0.18.Final (*Confidence*:High)
- cpe:2.3:a:hibernate:hibernate-validator:6.0.18:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:redhat:hibernate_validator:6.0.18:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

- cpe:2.3:a:validator:validator:6.0.18:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2025-15104 suppress

Nu Html Checker (validator.nu) contains a restriction bypass that allows remote attackers to make the server perform arbitrary HTTP/HTTPS requests to internal resources, including localhost services. While the validator implements hostname-based protections to block direct access to localhost and 127.0.0.1, these controls can be bypassed using DNS rebinding techniques or domains that resolve to loopback addresses.This issue affects The Nu Html Checker (vnu): latest (commit 23f090a11bab8d0d4e698f1ffc197a4fe226a9cd).

CWE-918 Server-Side Request Forgery (SSRF)

CVSSv4:
- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:L/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - EXPLOIT,THIRD_PARTY_ADVISORY
- help@fluidattacks.com - EXPLOIT,THIRD_PARTY_ADVISORY
- help@fluidattacks.com - PRODUCT

Vulnerable Software & Versions:

- cpe:2.3:a:validator:validator:*:*:*:*:*:*:*:* versions up to (excluding) 2026-01-11

CVE-2025-35036 suppress

Hibernate Validator before 6.2.0 and 7.0.0, by default and depending how it is used, may interpolate user-supplied input in a constraint violation message with Expression Language. This could allow an attacker to access sensitive information or execute arbitrary Java code. Hibernate Validator as of 6.2.0 and 7.0.0 no longer interpolates custom constraint violation messages with Expression Language and strongly recommends not allowing user-supplied input in constraint violation messages. CVE-2020-5245 and CVE-2025-4428 are examples of related, downstream vulnerabilities involving Expression Language intepolation of user-supplied data.

CWE-94 Improper Control of Generation of Code ('Code Injection')

CVSSv4:
- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- 9119a7d8-5eab-497f-8521-727c672e3725 - ISSUE_TRACKING
- 9119a7d8-5eab-497f-8521-727c672e3725 - ISSUE_TRACKING
- 9119a7d8-5eab-497f-8521-727c672e3725 - NOT_APPLICABLE
- 9119a7d8-5eab-497f-8521-727c672e3725 - NOT_APPLICABLE
- 9119a7d8-5eab-497f-8521-727c672e3725 - NOT_APPLICABLE
- 9119a7d8-5eab-497f-8521-727c672e3725 - PATCH
- 9119a7d8-5eab-497f-8521-727c672e3725 - PATCH
- 9119a7d8-5eab-497f-8521-727c672e3725 - PATCH
- 9119a7d8-5eab-497f-8521-727c672e3725 - PATCH
- 9119a7d8-5eab-497f-8521-727c672e3725 - PRODUCT
- 9119a7d8-5eab-497f-8521-727c672e3725 - RELEASE_NOTES
- 9119a7d8-5eab-497f-8521-727c672e3725 - RELEASE_NOTES
- 9119a7d8-5eab-497f-8521-727c672e3725 - RELEASE_NOTES

Vulnerable Software & Versions:

- cpe:2.3:a:redhat:hibernate_validator:*:-:*:*:*:*:*:* versions up to (excluding) 6.2.0

CVE-2023-1932 suppress

A flaw was found in hibernate-validator's 'isValid' method in the org.hibernate.validator.internal.constraintvalidators.hv.SafeHtmlValidator class, which can be bypassed by omitting the tag ending in a less-than character. Browsers may render an invalid html, allowing HTML injection or Cross-Site-Scripting (XSS) attacks.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- secalert@redhat.com - ISSUE_TRACKING,VENDOR_ADVISORY
- secalert@redhat.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:hibernate:hibernate-validator:*:*:*:*:*:*:*:* versions up to (excluding) 6.2
- ...

CVE-2020-10693 suppress

A flaw was found in Hibernate Validator version 6.1.2.Final. A bug in the message interpolation processor enables invalid EL expressions to be evaluated as if they were valid. This flaw allows attackers to bypass input sanitation (escaping, stripping) controls that developers may have put in place when handling user-controlled data in error messages.

CWE-20 Improper Input Validation

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:redhat:hibernate_validator:*:*:*:*:*:*:*:* versions from (including) 5.0.0; versions up to (excluding) 6.0.20
- ...

jackson-databind-2.10.2.jar

Description:

General data-binding functionality for Jackson: works on core streaming API

License:

http://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\com\fasterxml\jackson\core\jackson-databind\2.10.2\jackson-databind-2.10.2.jar
MD5: 057751b4e2dd1104be8caad6e9a3e589
SHA1: 0528de95f198afafbcfb0c09d2e43b6e0ea663ec
SHA256:42c25644e35fadfbded1b7f35a8d1e70a86737f190e43aa2c56cea4b96cbda88
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.10.2 (*Confidence*:High)
- cpe:2.3:a:fasterxml:jackson-core:2.10.2:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:fasterxml:jackson-databind:2.10.2:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:fasterxml:jackson-modules-java8:2.10.2:*:*:*:*:*:*:* (*Confidence*:Low) suppress

Published Vulnerabilities

CVE-2026-54512 suppress

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.10.0 until 2.18.8, 2.21.4, and 3.1.4, jackson-databind's PolymorphicTypeValidator (PTV) is the primary safety mechanism guarding polymorphic deserialization. When polymorphic typing is enabled and a type identifier contains generic parameters (i.e. the type ID string contains <), DatabindContext._resolveAndValidateGeneric() validates only the raw container class name (the substring before <) against the configured PTV. If the container type is approved, the method parses the full canonical type string via TypeFactory.constructFromCanonical() and returns the fully parameterized type without ever validating the nested type arguments against the PTV. The nested type arguments are then resolved, instantiated, and populated as beans during deserialization. An attacker who controls the type ID can therefore place a denied class as a generic type parameter of an allowed container — for example java.util.ArrayList<com.evil.Gadget> when only java.util.ArrayList is allow-listed. The container passes the PTV check; com.evil.Gadget is loaded via Class.forName(name, true, loader), instantiated, and its properties are set from attacker-controlled JSON. This completely bypasses an explicitly configured PTV allow-list. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

CWE-502 Deserialization of Untrusted Data, CWE-184 Incomplete List of Disallowed Inputs

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - EXPLOIT,VENDOR_ADVISORY
- security-advisories@github.com - EXPLOIT,VENDOR_ADVISORY
- security-advisories@github.com - ISSUE_TRACKING,PATCH
- security-advisories@github.com - PATCH

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.10.0; versions up to (excluding) 2.18.8
- ...

CVE-2026-54513 suppress

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.10.0 until 2.18.8, 2.21.4, and 3.1.4, BasicPolymorphicTypeValidator.Builder.allowIfSubTypeIsArray() allowlists any array type based only on clazz.isArray(), without validating the array's component (element) type against the configured allowlist. A PTV built with allowIfSubTypeIsArray() plus an explicit concrete-type allowlist therefore still permits EvilType[] even

though EvilType is not allowlisted. When Jackson deserializes the elements and no per-element type IDs are present, it instantiates the component type directly with no further PTV check, bypassing the allowlist. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

CWE-184 Incomplete List of Disallowed Inputs

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:
- security-advisories@github.com - ISSUE_TRACKING
- security-advisories@github.com - ISSUE_TRACKING,PATCH
- security-advisories@github.com - ISSUE_TRACKING,PATCH
- security-advisories@github.com - PATCH
- security-advisories@github.com - PATCH
- security-advisories@github.com - PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.10.0; versions up to (excluding) 2.18.8
- ...

CVE-2020-25649 suppress

A flaw was found in FasterXML Jackson Databind, where it did not have entity expansion secured properly. This flaw allows vulnerability to XML external entity (XXE) attacks. The highest threat from this vulnerability is data integrity.

CWE-611 Improper Restriction of XML External Entity Reference

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- secalert@redhat.com - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - PATCH,THIRD_PARTY_ADVISORY
- secalert@redhat.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.10.0; versions up to (excluding) 2.10.5.1
- ...

CVE-2020-36518 suppress

jackson-databind before 2.13.0 allows a Java StackOverflow exception and denial of service via a large depth of nested objects.

CWE-787 Out-of-bounds Write

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions up to (excluding) 2.12.6.1
- ...

CVE-2021-46877 suppress

jackson-databind 2.10.x through 2.12.x before 2.12.6 and 2.13.x before 2.13.1 allows attackers to cause a denial of service (2 GB transient heap usage per read) in uncommon situations involving JsonNode JDK serialization.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,VENDOR_ADVISORY
- cve@mitre.org - MAILING_LIST,RELEASE_NOTES

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.10.0; versions up to (excluding) 2.12.6
- ...

CVE-2022-42003 suppress

In FasterXML jackson-databind before versions 2.13.4.1 and 2.12.17.1, resource exhaustion can occur because of a lack of a check in primitive value deserializers to avoid deep wrapper array nesting, when the UNWRAP_SINGLE_VALUE_ARRAYS feature is enabled.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions up to (excluding) 2.12.7.1
- ...

CVE-2022-42004 suppress

In FasterXML jackson-databind before 2.13.4, resource exhaustion can occur because of a lack of a check in BeanDeserializer._deserializeFromArray to prevent use of deeply nested arrays. An application is vulnerable only with certain customized choices for deserialization.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions up to (excluding) 2.12.7.1
- ...

CVE-2026-50193 suppress

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.13.0 until 2.14.0, a potential Denial-of-Service exists when attacker sends deeply nested JSON if (and only if) the service reads deeply nested (1000s of levels) JSON as JsonNode (ObjectMapper.readTree()) and writes out same (or modified) node using JsonNode.toString(). This can consume significant amount of resources with concurrent relatively small requests (1000 nested arrays is 2kB). This vulnerability is fixed in 2.14.0.

CWE-400 Uncontrolled Resource Consumption

CVSSv4:
- Base Score: MEDIUM (6.3)
- Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security-advisories@github.com - EXPLOIT,ISSUE_TRACKING
- security-advisories@github.com - PATCH
- security-advisories@github.com - PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.10.0; versions up to (excluding) 2.14.0

CVE-2026-54514 suppress

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.0.0 until 2.18.8, 2.21.4, and 3.1.4, JDKFromStringDeserializer constructed InetSocketAddress with new InetSocketAddress(host, port), which performs eager DNS name resolution for hostname inputs at deserialization time. An application that binds untrusted JSON into a type containing an InetSocketAddress field issues an attacker-chosen DNS query during readValue, before any application-level validation or connect logic. The fix uses InetSocketAddress.createUnresolved(host, port), deferring DNS to an explicit connect. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

CWE-918 Server-Side Request Forgery (SSRF)

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- security-advisories@github.com - ISSUE_TRACKING,PATCH
- security-advisories@github.com - PATCH
- security-advisories@github.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.0.0; versions up to (excluding) 2.18.8
- ...

CVE-2026-54515 suppress

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.8.0 until 2.18.9, 2.21.5, and 3.1.4, in BeanDeserializerBase.createContextual(), per-property @JsonIgnoreProperties exclusions are applied by _handleByNameInclusion(), producing a contextual deserializer whose BeanPropertyMap has the ignored properties removed. The subsequent per-property case-insensitivity block (triggered by @JsonFormat(ACCEPT_CASE_INSENSITIVE_PROPERTIES)) rebuilds from this._beanProperties (the original, unfiltered map) instead of contextual._beanProperties, then overwrites the filtered map — restoring every property _handleByNameInclusion had just removed. The ignored property becomes writable again. This vulnerability is fixed in 2.18.9, 2.21.5, and 3.1.4.

CWE-915 Improperly Controlled Modification of Dynamically-Determined Object Attributes

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- security-advisories@github.com - ISSUE_TRACKING
- security-advisories@github.com - ISSUE_TRACKING,PATCH
- security-advisories@github.com - PATCH
- security-advisories@github.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions from (including) 2.8.0; versions up to (excluding) 2.18.9
- ...

CVE-2023-35116 suppress

jackson-databind through 2.15.2 allows attackers to cause a denial of service or other unspecified impact via a crafted object that uses cyclic dependencies. NOTE: the vendor's perspective is that this is not a valid vulnerability report, because the steps of constructing a cyclic data structure and trying to serialize it cannot be achieved by an external attacker.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (4.7)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.0/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- cve@mitre.org - ISSUE_TRACKING

Vulnerable Software & Versions:

- cpe:2.3:a:fasterxml:jackson-databind:*:*:*:*:*:*:*:* versions up to (excluding) 2.16.0

log4j-api-2.12.1.jar

Description:

The Apache Log4j API

License:

https://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\org\apache\logging\log4j\log4j-api\2.12.1\log4j-api-2.12.1.jar
MD5: 4a6f276d4fb426c8d489343c0325bb75
SHA1: a55e6d987f50a515c9260b0451b4fa217dc539cb
SHA256:429534d03bdb728879ab551d469e26f6f7ff4c8a8627f59ac68ab6ef26063515
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1 (*Confidence*:High)
- cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2026-34479 suppress

The Log4j1XmlLayout from the Apache Log4j 1-to-Log4j 2 bridge fails to escape characters forbidden by the XML 1.0 standard, producing malformed XML output. Conforming XML parsers are required to reject documents containing such characters with a fatal error, which may cause downstream log processing systems to drop or fail to index affected records.

Two groups of users are affected:

* Those using Log4j1XmlLayout directly in a Log4j Core 2 configuration file.
* Those using the Log4j 1 configuration compatibility layer with org.apache.log4j.xml.XMLLayout specified as the layout class.

Users are advised to upgrade to Apache Log4j 1-to-Log4j 2 bridge version 2.25.4, which corrects this issue.

Note: The Apache Log4j 1-to-Log4j 2 bridge is deprecated and will not be present in Log4j 3. Users are encouraged to consult the Log4j 1 to Log4j 2 migration guide https://logging.apache.org/log4j/2.x/migrate-from-log4j1.html , and specifically the section on eliminating reliance on the bridge.

CWE-116 Improper Encoding or Escaping of Output

CVSSv4:
- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- security@apache.org - EXPLOIT,ISSUE_TRACKING,PATCH
- security@apache.org - MAILING_LIST
- security@apache.org - MITIGATION
- security@apache.org - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:log4j:*:*:*:*:*:*:*:* versions from (including) 2.7; versions up to (excluding) 2.25.4
- ...

CVE-2026-34480 suppress

Apache Log4j Core's XmlLayout https://logging.apache.org/log4j/2.x/manual/layouts.html#XmlLayout , in versions up to and including 2.25.3, fails to sanitize characters forbidden by the XML 1.0 specification https://www.w3.org/TR/xml/#charsets producing invalid XML output whenever a log message or MDC value contains such characters.

The impact depends on the StAX implementation in use:

* JRE built-in StAX: Forbidden characters are silently written to the output, producing malformed XML. Conforming parsers must reject such documents with a fatal error, which may cause downstream log-processing systems to drop the affected records.
* Alternative StAX implementations (e.g., Woodstox https://github.com/FasterXML/woodstox , a transitive dependency of the Jackson XML Dataformat module): An exception is thrown during the logging call, and the log event is never delivered to its intended appender, only to Log4j's internal status logger.

Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue by sanitizing forbidden characters before XML output.

CWE-116 Improper Encoding or Escaping of Output

CVSSv4:
- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,PATCH
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PRODUCT

- security@apache.org - TECHNICAL_DESCRIPTION
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:log4j:*:*:*:*:*:*:*:* versions from (including) 2.0; versions up to (excluding) 2.25.4
- ...

CVE-2025-68161 suppress

The Socket Appender in Apache Log4j Core versions 2.0-beta9 through 2.25.2 does not perform TLS hostname verification of the peer certificate, even when the verifyHostName https://logging.apache.org/log4j/2.x/manual/appenders/network.html#SslConfiguration-attr-verifyHostName configuration attribute or the log4j2.sslVerifyHostName https://logging.apache.org/log4j/2.x/manual/systemproperties.html#log4j2.sslVerifyHostName system property is set to true.

This issue may allow a man-in-the-middle attacker to intercept or redirect log traffic under the following conditions:

* The attacker is able to intercept or redirect network traffic between the client and the log receiver.
* The attacker can present a server certificate issued by a certification authority trusted by the Socket Appender's configured trust store (or by the default Java trust store if no custom trust store is configured).

Users are advised to upgrade to Apache Log4j Core version 2.25.3, which addresses this issue.

As an alternative mitigation, the Socket Appender may be configured to use a private or restricted trust root to limit the set of trusted certificates.

CWE-295 Improper Certificate Validation, CWE-297 Improper Validation of Certificate with Host Mismatch

CVSSv4:
- Base Score: MEDIUM (6.3)
- Vector: CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- security@apache.org - EXPLOIT,VENDOR_ADVISORY
- security@apache.org - ISSUE_TRACKING,PATCH
- security@apache.org - MAILING_LIST
- security@apache.org - PRODUCT
- security@apache.org - PRODUCT
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:log4j:*:*:*:*:*:*:*:* versions from (including) 2.0.1; versions up to (excluding) 2.25.3
- ...

CVE-2026-34477 suppress

The fix for CVE-2025-68161 https://logging.apache.org/security.html#CVE-2025-68161 was incomplete: it addressed hostname verification only when enabled via the log4j2.sslVerifyHostName https://logging.apache.org/log4j/2.x/manual/systemproperties.html#log4j2.sslVerifyHostName system property, but not when configured through the verifyHostName https://logging.apache.org/log4j/2.x/manual/appenders/network.html#SslConfiguration-attr-verifyHostName attribute of the <Ssl> element.

Although the verifyHostName configuration attribute was introduced in Log4j Core 2.12.0, it was silently ignored in all versions through 2.25.3, leaving TLS connections vulnerable to interception regardless of the configured value.

A network-based attacker may be able to perform a man-in-the-middle attack when all of the following conditions are met:

* An SMTP, Socket, or Syslog appender is in use.
* TLS is configured via a nested <Ssl> element.
* The attacker can present a certificate issued by a CA trusted by the appender's configured trust store, or by the default Java trust store if none is configured.

This issue does not affect users of the HTTP appender, which uses a separate verifyHostname https://logging.apache.org/log4j/2.x/manual/appenders/network.html#HttpAppender-attr-verifyHostName attribute that was not subject to this bug and verifies host names by default.

Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue.

CWE-295 Improper Certificate Validation, CWE-297 Improper Validation of Certificate with Host Mismatch

CVSSv4:
- Base Score: MEDIUM (6.3)
- Vector: CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA:X/S:X

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N/E:2.2/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,PATCH
- security@apache.org - MAILING_LIST
- security@apache.org - PRODUCT
- security@apache.org - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:log4j:*:*:*:*:*:*:*:* versions from (including) 2.12.0; versions up to (excluding) 2.25.4
- ...

CVE-2020-9488 suppress

Improper validation of certificate with host mismatch in Apache Log4j SMTP appender. This could allow an SMTPS connection to be intercepted by a man-in-the-middle attack which could leak any log messages sent through that appender. Fixed in Apache Log4j 2.12.3 and 2.13.1

CWE-295 Improper Certificate Validation

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MITIGATION,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,MITIGATION,PATCH,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:log4j:*:*:*:*:*:*:*:* versions from (including) 2.4; versions up to (excluding) 2.12.3
- ...

logback-core-1.2.3.jar

Description:

logback-core module

License:

http://www.eclipse.org/legal/epl-v10.html, http://www.gnu.org/licenses/old-licenses/lgpl-2.1.html

File Path: C:\Users\Grace School\.m2\repository\ch\qos\logback\logback-core\1.2.3\logback-core-1.2.3.jar
MD5: 841fc80c6edff60d947a3872a2db4d45
SHA1: 864344400c3d4d92dfeb0a305dc87d953677c03c
SHA256:5946d837fe6f960c02a53eda7a6926ecc3c758bbdd69aa453ee429f858217f22
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Related Dependencies

Identifiers

- pkg:maven/ch.qos.logback/logback-core@1.2.3 (*Confidence*:High)
- cpe:2.3:a:qos:logback:1.2.3:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2023-6378 suppress

A serialization vulnerability in logback receiver component part of logback version 1.4.11 allows an attacker to mount a Denial-Of-Service attack by sending poisoned data.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- vulnerability@ncsc.ch - RELEASE_NOTES

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:qos:logback:*:*:*:*:*:*:*:* versions from (including) 1.2.0; versions up to (excluding) 1.2.13
- ...

CVE-2021-42550 suppress

In logback version 1.2.7 and prior versions, an attacker with the required privileges to edit configurations files could craft a malicious configuration allowing to execute arbitrary code loaded from LDAP servers.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: MEDIUM (6.6)
- Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.7/RC:R/MAV:A

CVSSv2:
- Base Score: HIGH (8.5)
- Vector: /AV:N/AC:M/Au:S/C:C/I:C/A:C

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- vulnerability@ncsc.ch - EXPLOIT,ISSUE_TRACKING,PATCH,THIRD_PARTY_ADVISORY
- vulnerability@ncsc.ch - EXPLOIT,THIRD_PARTY_ADVISORY
- vulnerability@ncsc.ch - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- vulnerability@ncsc.ch - MAILING_LIST,THIRD_PARTY_ADVISORY
- vulnerability@ncsc.ch - THIRD_PARTY_ADVISORY
- vulnerability@ncsc.ch - THIRD_PARTY_ADVISORY
- vulnerability@ncsc.ch - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:qos:logback:*:*:*:*:*:*:*:* versions up to (including) 1.2.7
- ...

snakeyaml-1.25.jar

Description:

YAML 1.1 parser and emitter for Java

License:

Apache License, Version 2.0: http://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\org\yaml\snakeyaml\1.25\snakeyaml-1.25.jar
MD5: 6f7d5b8f596047aae07a3bf6f23a0bf2
SHA1: 8b6e01ef661d8378ae6dd7b511a7f2a33fae1421
SHA256:b50ef33187e7dc922b26dbe4dd0fdb3a9cf349e75a08b95269901548eee546eb
Referenced In Project/Scope: rest-service:runtime
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.yaml/snakeyaml@1.25 (*Confidence*:High)
- cpe:2.3:a:snakeyaml_project:snakeyaml:1.25:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2022-1471 suppress

SnakeYaml's Constructor() class does not restrict types which can be instantiated during deserialization. Deserializing yaml content provided by an attacker can lead to remote code execution. We recommend using SnakeYaml's SafeConsturctor when parsing untrusted content to restrict deserialization. We recommend upgrading to version 2.0 and beyond.

CWE-502 Deserialization of Untrusted Data, CWE-20 Improper Input Validation

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY

- cve-coordination@google.com - EXPLOIT,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - EXPLOIT,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - EXPLOIT,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - ISSUE_TRACKING,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 2.0

CVE-2017-18640 suppress

The Alias feature in SnakeYAML before 1.26 allows entity expansion during a load operation, a related issue to CVE-2003-1564.

CWE-776 Improper Restriction of Recursive Entity References in DTDs ('XML Entity Expansion')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.26
- ...

CVE-2022-25857 suppress

The package org.yaml:snakeyaml from 0 and before 1.31 are vulnerable to Denial of Service (DoS) due missing to nested depth limitation for collections.

CWE-776 Improper Restriction of Recursive Entity References in DTDs ('XML Entity Expansion')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- report@snyk.io - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- report@snyk.io - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY
- report@snyk.io - MAILING_LIST,THIRD_PARTY_ADVISORY
- report@snyk.io - PATCH,THIRD_PARTY_ADVISORY
- report@snyk.io - PATCH,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.31

CVE-2022-38749 suppress

Using snakeYAML to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stackoverflow.

CWE-787 Out-of-bounds Write, CWE-121 Stack-based Buffer Overflow

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve-coordination@google.com - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - THIRD_PARTY_ADVISORY
- cve-coordination@google.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.31

CVE-2022-38751 suppress

Using snakeYAML to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stackoverflow.

CWE-787 Out-of-bounds Write, CWE-121 Stack-based Buffer Overflow

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve-coordination@google.com - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - THIRD_PARTY_ADVISORY
- cve-coordination@google.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.31

CVE-2022-38752 suppress

Using snakeYAML to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stack-overflow.

CWE-787 Out-of-bounds Write, CWE-121 Stack-based Buffer Overflow

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - PERMISSIONS_REQUIRED
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve-coordination@google.com - PERMISSIONS_REQUIRED
- cve-coordination@google.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.32

CVE-2022-41854 suppress

Those using Snakeyaml to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stack overflow. This effect may support a denial of service attack.

CWE-787 Out-of-bounds Write, CWE-121 Stack-based Buffer Overflow

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.32

CVE-2022-38750 suppress

Using snakeYAML to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stackoverflow.

CWE-787 Out-of-bounds Write, CWE-121 Stack-based Buffer Overflow

CVSSv3:
- Base Score: MEDIUM (5.5)
- Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H/E:1.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - EXPLOIT,ISSUE_TRACKING,MAILING_LIST,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - EXPLOIT,ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve-coordination@google.com - MAILING_LIST,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:snakeyaml_project:snakeyaml:*:*:*:*:*:*:*:* versions up to (excluding) 1.31

spring-boot-2.2.4.RELEASE.jar

Description:

Spring Boot

License:

Apache License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0

File Path: C:\Users\Grace School\.m2\repository\org\springframework\boot\spring-boot\2.2.4.RELEASE\spring-boot-2.2.4.RELEASE.jar
MD5: 24de0cfd8ea74b903b562b43cbc5eb13
SHA1: 225a4fd31156c254e3bb92adb42ee8c6de812714
SHA256:176befc7b90e8498f44e21994a70d69ba360ef1e858ff3cea8282e802372daf2
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Related Dependencies

Identifiers

- pkg:maven/org.springframework.boot/spring-boot@2.2.4.RELEASE (*Confidence*:High)
- cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2023-20873 suppress

In Spring Boot versions 3.0.0 - 3.0.5, 2.7.0 - 2.7.10, and older unsupported versions, an application that is deployed to Cloud Foundry could be susceptible to a security bypass. Users of affected versions should apply the following mitigation: 3.0.x users should upgrade to 3.0.6+. 2.7.x users should upgrade to 2.7.11+. Users of older, unsupported versions should upgrade to 3.0.6+ or 2.7.11+.

NVD-CWE-noinfo

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.5.15
- ...

CVE-2026-22733 suppress

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under the path used by the CloudFoundry Actuator endpoints. This issue affects Spring Security: from 4.0.0 through 4.0.3, from 3.5.0 through 3.5.11, from 3.4.0 through 3.4.14, from 3.3.0 through 3.3.17, from 2.7.0 through 2.7.31.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.32
- ...

CVE-2022-27772 suppress

spring-boot versions prior to version v2.2.11.RELEASE was vulnerable to temporary directory hijacking. This vulnerability impacted the org.springframework.boot.web.server.AbstractConfigurableWebServerFactory.createTempDir method. NOTE: This vulnerability only affects products and/or versions that are no longer supported by the maintainer

CWE-668 Exposure of Resource to Wrong Sphere

CVSSv3:
- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.6)
- Vector: /AV:L/AC:L/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.2.11

CVE-2023-20883 suppress

In Spring Boot versions 3.0.0 - 3.0.6, 2.7.0 - 2.7.11, 2.6.0 - 2.6.14, 2.5.0 - 2.5.14 and older unsupported versions, there is potential for a denial-of-service (DoS) attack if Spring MVC is used together with a reverse proxy cache.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.5.14
- ...

CVE-2026-40972 suppress

An attacker on the same network as the remote application may be able to utilize a timing attack to discover information about the remote secret. In extreme circumstances this could result in the attacker determining the secret and uploading changed classes, thereby achieving remote code execution in the remote application.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); DevTools remote secret comparison. Versions that are no longer supported are also affected per vendor advisory.

CWE-208 Observable Timing Discrepancy

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40975 suppress

Values produced by ${random.value} are not suitable for use as secrets. ${random.uuid} is not affected. ${random.int} and ${random.long} should never be used for secrets as they are numeric values with a predictable range.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); random value property source / weak PRNG for secrets. Versions that are no longer supported are also affected per vendor advisory.

CWE-338 Use of Cryptographically Weak Pseudo-Random Number Generator (PRNG), CWE-330 Use of Insufficiently Random Values

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40973 suppress

A local attacker on the same host as the application may be able to take control of the directory used by `ApplicationTemp`. When `server.servlet.session.persistent` is set to `true` and the attack persists across application restarts, this may allow the attacker to read session information and hijack authenticated users or deploy a gadget chain and execute code as the application's user.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); predictable temp directory / `ApplicationTemp` ownership verification. Versions that are no longer supported are also affected per vendor advisory.

CWE-377 Insecure Temporary File

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40977 suppress

When an application is configured to use `ApplicationPidFileWriter`, a local attacker with write access to the PID file's location can corrupt one file on the host each time the application is started.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); PID file / symlink behavior (`ApplicationPidFileWriter`). Versions that are no longer supported are also affected per vendor advisory.

CWE-59 Improper Link Resolution Before File Access ('Link Following')

CVSSv3:

- Base Score: MEDIUM (6.7)
- Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-41001 suppress

Spring Boot's ArtemisEmbeddedConfigurationFactory uses a fixed, static path for the embedded Artemis message broker's data directory when no explicit path is configured. A local attacker on the same host can pre-create this predictable directory or place a symlink before the application starts.

Affected versions:
Spring Boot 4.0.0 through 4.0.6; 3.5.0 through 3.5.14; 3.4.0 through 3.4.16; 3.3.0 through 3.3.19; 2.7.0 through 2.7.33.

CWE-377 Insecure Temporary File

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L/E:1.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.34
- ...

spring-boot-starter-web-2.2.4.RELEASE.jar

Description:

Starter for building web, including RESTful, applications using Spring
MVC. Uses Tomcat as the default embedded container

License:

Apache License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0

File Path: C:\Users\Grace School\.m2\repository\org\springframework\boot\spring-boot-starter-web\2.2.4.RELEASE\spring-boot-starter-web-2.2.4.RELEASE.jar
MD5: 0fd2927b6235bdbaa0d4d12c28a847c2
SHA1: ec75d01d212b5229c16d872fb127744c0ed46ed8
SHA256:eb4d4ad19fe1724fd02cfce9c467c0b67766b5a4a54d0e54fc51826d9e3d87b8
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/com.twk/rest-service@0.0.1-SNAPSHOT

Evidence

Identifiers

- pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE (*Confidence*:High)
- cpe:2.3:a:vmware:spring_boot:2.2.4:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:web_project:web:2.2.4:release:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2023-20873 suppress

In Spring Boot versions 3.0.0 - 3.0.5, 2.7.0 - 2.7.10, and older unsupported versions, an application that is deployed to Cloud Foundry could be susceptible to a security bypass. Users of affected versions should apply the following mitigation: 3.0.x users should upgrade to 3.0.6+. 2.7.x users should upgrade to 2.7.11+. Users of older, unsupported versions should upgrade to 3.0.6+ or 2.7.11+.

NVD-CWE-noinfo

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.5.15
- ...

CVE-2026-22733 suppress

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under the path used by the CloudFoundry Actuator endpoints. This issue affects Spring Security: from 4.0.0 through 4.0.3, from 3.5.0 through 3.5.11, from 3.4.0 through 3.4.14, from 3.3.0 through 3.3.17, from 2.7.0 through 2.7.31.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.32
- ...

CVE-2022-27772 suppress

spring-boot versions prior to version v2.2.11.RELEASE was vulnerable to temporary directory hijacking. This vulnerability impacted the org.springframework.boot.web.server.AbstractConfigurableWebServerFactory.createTempDir method. NOTE: This vulnerability only affects products and/or versions that are no longer supported by the maintainer

CWE-668 Exposure of Resource to Wrong Sphere

CVSSv3:
- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.6)
- Vector: /AV:L/AC:L/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,PATCH,THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.2.11

CVE-2023-20883 suppress

In Spring Boot versions 3.0.0 - 3.0.6, 2.7.0 - 2.7.11, 2.6.0 - 2.6.14, 2.5.0 - 2.5.14 and older unsupported versions, there is potential for a denial-of-service (DoS) attack if Spring MVC is used together with a reverse proxy cache.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.5.14
- ...

CVE-2026-40972 suppress

An attacker on the same network as the remote application may be able to utilize a timing attack to discover information about the remote secret. In extreme circumstances this could result in the attacker determining the secret and uploading changed classes, thereby achieving remote code execution in the remote application.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); DevTools remote secret comparison. Versions that are no longer supported are also affected per vendor advisory.

CWE-208 Observable Timing Discrepancy

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40975 suppress

Values produced by ${random.value} are not suitable for use as secrets. ${random.uuid} is not affected. ${random.int} and ${random.long} should never be used for secrets as they are numeric values with a predictable range.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); random value property source / weak PRNG for secrets. Versions that are no longer supported are also affected per vendor advisory.

CWE-338 Use of Cryptographically Weak Pseudo-Random Number Generator (PRNG), CWE-330 Use of Insufficiently Random Values

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40973 suppress

A local attacker on the same host as the application may be able to take control of the directory used by `ApplicationTemp`. When `server.servlet.session.persistent` is set to `true` and the attack persists across application restarts, this may allow the attacker to read session information and hijack authenticated users or deploy a gadget chain and execute code as the application's user.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); predictable temp directory / `ApplicationTemp` ownership verification. Versions that are no longer supported are also affected per vendor advisory.

CWE-377 Insecure Temporary File

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-40977 suppress

When an application is configured to use `ApplicationPidFileWriter`, a local attacker with write access to the PID file's location can corrupt one file on the host each time the application is started.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); PID file / symlink behavior (`ApplicationPidFileWriter`). Versions that are no longer supported are also affected per vendor advisory.

CWE-59 Improper Link Resolution Before File Access ('Link Following')

CVSSv3:
- Base Score: MEDIUM (6.7)
- Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.33
- ...

CVE-2026-41001 suppress

Spring Boot's ArtemisEmbeddedConfigurationFactory uses a fixed, static path for the embedded Artemis message broker's data directory when no explicit path is configured. A local attacker on the same host can pre-create this predictable directory or place a symlink before the application starts.

Affected versions:
Spring Boot 4.0.0 through 4.0.6; 3.5.0 through 3.5.14; 3.4.0 through 3.4.16; 3.3.0 through 3.3.19; 2.7.0 through 2.7.33.

CWE-377 Insecure Temporary File

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L/E:1.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_boot:*:*:*:*:*:*:*:* versions up to (excluding) 2.7.34
- ...

spring-core-5.2.3.RELEASE.jar

Description:

Spring Core

License:

Apache License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0

File Path: C:\Users\Grace School\.m2\repository\org\springframework\spring-core\5.2.3.RELEASE\spring-core-5.2.3.RELEASE.jar
MD5: ae11e44d9eff630186b9e095e70b59de
SHA1: 3734223040040e8c3fecd5faa3ae8a1ed6da146b
SHA256:6df908f4deaeefd2b03b56a00246cc0dc0d941d9636e811025bc6fc5a2a44851
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-test@2.2.4.RELEASE

Evidence

Related Dependencies

Identifiers

- pkg:maven/org.springframework/spring-core@5.2.3.RELEASE (*Confidence*:High)
- cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2022-22965 suppress

CISA Known Exploited Vulnerability:
- Product: VMware Spring Framework
- Name: Spring Framework JDK 9+ Remote Code Execution Vulnerability
- Date Added: 2022-04-04
- Description: Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding.
- Required Action: Apply updates per vendor instructions.
- Due Date: 2022-04-25
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2022-22965

A Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding. The specific exploit requires the application to run on Tomcat as a WAR deployment. If the application is deployed as a Spring Boot executable jar, i.e. the default, it is not vulnerable to the exploit. However, the nature of the vulnerability is more general, and there may be other ways to exploit it.

CWE-94 Improper Control of Generation of Code ('Code Injection')

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - US_GOVERNMENT_RESOURCE
- security@vmware.com - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2026-47884 suppress

Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/**" mapping that results in view rendering, and where the view name is not explicitly specified.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47891 suppress

A Spring WebFlux application that relies on the Aalto XML processor to parse XML input does not correctly enforce the maxInMemorySize limit.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59283 suppress

Applications that evaluate Spring Expression Language (SpEL) expressions using SimpleEvaluationContext may be vulnerable to a safety guard bypass when the SpEL expression compiler is active.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-913 Improper Control of Dynamically-Managed Code Resources

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2024-22259 suppress

Applications that use UriComponentsBuilder in Spring Framework to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks.

This is the same as CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.33
- ...

CVE-2021-22118 suppress

In Spring Framework, versions 5.2.x prior to 5.2.15 and versions 5.3.x prior to 5.3.7, a WebFlux application is vulnerable to a privilege escalation: by (re)creating the temporary storage directory, a locally authenticated malicious user can read or modify files that have been uploaded to the WebFlux application, or overwrite arbitrary files with multipart request data.

CWE-269 Improper Privilege Management, CWE-668 Exposure of Resource to Wrong Sphere

CVSSv3:
- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.6)
- Vector: /AV:L/AC:L/Au:N/C:P/I:P/A:P

References:

- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.15
- ...

CVE-2026-47886 suppress

Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47888 suppress

A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE

CWE-401 Missing Release of Memory after Effective Lifetime

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.26
- ...

CVE-2026-47893 suppress

A Spring WebFlux application that supports WebSocket connections may expose indirectly sensitive user information by including request headers in an exception reason.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59282 suppress

Spring Framework applications that use Spring's data binding infrastructure to apply user-supplied property paths onto a target object may be vulnerable to a Denial of Service (DoS) attack.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2020-5421 suppress

In Spring Framework versions 5.2.0 - 5.2.8, 5.1.0 - 5.1.17, 5.0.0 - 5.0.18, 4.3.0 - 4.3.28, and older unsupported versions, the protections against RFD attacks from CVE-2015-5211 may be bypassed depending on the browser used through the use of a jsessionid path parameter.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:H/A:N/E:1.3/RC:R/MAV:A

CVSSv2:
- Base Score: LOW (3.6)
- Vector: /AV:N/AC:H/Au:S/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@pivotal.io - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - THIRD_PARTY_ADVISORY
- security@pivotal.io - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.9
- ...

CVE-2022-22950 suppress

n Spring Framework versions 5.3.0 - 5.3.16 and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial of service condition.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2022-22971 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, application with a STOMP over WebSocket endpoint is vulnerable to a denial of service attack by an authenticated user.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.21
- ...

CVE-2023-20861 suppress

In Spring Framework versions 6.0.0 - 6.0.6, 5.3.0 - 5.3.25, 5.2.0.RELEASE - 5.2.22.RELEASE, and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.22
- ...

CVE-2023-20863 suppress

In spring framework versions prior to 5.2.24 release+ ,5.3.27+ and 6.0.8+ , it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, CWE-917 Improper Neutralization of Special Elements used in an Expression Language Statement ('Expression Language Injection')

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.24
- ...

CVE-2026-22740 suppress

A WebFlux server application that processes multipart requests creates temp files for parts larger than 10 K. Under some circumstances, temp files may remain not deleted after the request is fully processed. This allows an attacker to consume available disk space.

Older, unsupported versions are also affected.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2026-47887 suppress

A Spring MVC application that uses UrlFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59281 suppress

Spring MVC and WebFlux applications that obtain a data-binding Errors instance with HTML escaping enabled and then render field errors using the no-argument Errors.getFieldErrors() or Errors.getFieldError() accessors are vulnerable to arbitrary HTML/JavaScript code injection, potentially resulting in a reflected cross-site scripting (XSS) vulnerability.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-22737 suppress

Use of Java scripting engine enabled (e.g. JRuby, Jython) template views in Spring MVC and Spring WebFlux applications can result in disclosure of content from files outside the configured locations for script template views. This issue affects Spring Framework: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

CVE-2022-22968 suppress

In Spring Framework versions 5.3.0 - 5.3.18, 5.2.0 - 5.2.20, and older unsupported versions, the patterns for disallowedFields on a DataBinder are case sensitive which means a field is not effectively protected unless it is listed with both upper and lower case for the first character of the field, including upper and lower case for the first character of all nested fields within the property path.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.20
- ...

CVE-2022-22970 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, applications that handle file uploads are vulnerable to DoS attack if they rely on data binding to set a MultipartFile or javax.servlet.Part to a field in a model object.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.6/RC:R/MAV:A

CVSSv2:
- Base Score: LOW (3.5)
- Vector: /AV:N/AC:M/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.21
- ...

CVE-2026-22745 suppress

Spring MVC and WebFlux applications are vulnerable to Denial of Service attacks when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

* the application is using Spring MVC or Spring WebFlux
* the application is serving static resources from the file system
* the application is running on a Windows platform

When all the conditions above are met, the attacker can send malicious requests that are slow to resolve and that can keep HTTP connections in use. This can cause a Denial of Service on the application.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2021-22060 suppress

In Spring Framework versions 5.3.0 - 5.3.13, 5.2.0 - 5.2.18, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries. This is a follow-up to CVE-2021-22096 that protects against additional types of input and in more places of the Spring Framework codebase.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.18
- ...

CVE-2021-22096 suppress

In Spring Framework versions 5.3.0 - 5.3.10, 5.2.0 - 5.2.17, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries.

CWE-117 Improper Output Neutralization for Logs, NVD-CWE-Other

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.17
- ...

CVE-2026-59280 suppress

Applications using Spring Framework's FreeMarker integration may be vulnerable to a path traversal attack when a controller returns a view name derived from untrusted input and FreeMarker is configured to resolve templates through SpringTemplateLoader.

Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-41839 suppress

A WebFlux application with a compromised subdomain (for example, compromised via cross-site scripting (XSS)) is vulnerable to an escalation attack exchanging a known session ID for that of an authenticated user.

Affected versions:
Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

CWE-384 Session Fixation

CVSSv3:
- Base Score: MEDIUM (4.2)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.49
- ...

CVE-2026-59314 suppress

Applications that build a Content-Disposition header value from untrusted input may be vulnerable to HTTP response splitting when the input is a malicious file name.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

NVD-CWE-Other, CWE-113 Improper Neutralization of CRLF Sequences in HTTP Headers ('HTTP Request/Response Splitting')

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.25
- ...

CVE-2026-22741 suppress

Spring MVC and WebFlux applications are vulnerable to cache poisoning when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

 * the application is using Spring MVC or Spring WebFlux
 * the application is configuring the resource chain support https://docs.spring.io/spring-framework/reference/web/webmvc/mvc-config/static-resources.html#page-title with caching enabled
 * the application adds support for encoded resources resolution
 * the resource cache must be empty when the attacker has access to the application

When all the conditions above are met, the attacker can send malicious requests and poison the resource cache with resources using the wrong encoding. This can cause a denial of service by breaking the front-end application for clients.

CWE-524 Use of Cache Containing Sensitive Information

CVSSv3:
- Base Score: LOW (3.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:L/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48

- ...

CVE-2026-22735 suppress

Spring MVC and WebFlux applications are vulnerable to stream corruption when using Server-Sent Events (SSE). This issue affects Spring Foundation: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-667 Improper Locking

CVSSv3:
- Base Score: LOW (2.6)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:N/E:1.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

spring-web-5.2.3.RELEASE.jar

Description:

Spring Web

License:

Apache License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0

File Path: C:\Users\Grace School\.m2\repository\org\springframework\spring-web\5.2.3.RELEASE\spring-web-5.2.3.RELEASE.jar
MD5: a89d66690cd14159aa6ac1e875e54411
SHA1: dd386a02e40b915ab400a3bf9f586d2dc4c0852c
SHA256:25d264969c624cb8103a7f2b36b148ea1be8b87780c4758e7f9a6e2bc8416d76
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.springframework/spring-web@5.2.3.RELEASE (*Confidence*:High)
- cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:web_project:web:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2016-1000027 suppress

Pivotal Spring Framework through 5.3.16 suffers from a potential remote code execution (RCE) issue if used for Java deserialization of untrusted data. Depending on how the library is implemented within a product, this issue may or not occur, and authentication may be required. NOTE: the vendor's position is that untrusted data is not an intended use case. The product's behavior will not be changed because some users rely on deserialization of trusted data.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- cve@mitre.org - BROKEN_LINK,EXPLOIT,THIRD_PARTY_ADVISORY
- cve@mitre.org - EXPLOIT,THIRD_PARTY_ADVISORY
- cve@mitre.org - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 6.0.0

CVE-2022-22965 suppress

CISA Known Exploited Vulnerability:
- Product: VMware Spring Framework
- Name: Spring Framework JDK 9+ Remote Code Execution Vulnerability
- Date Added: 2022-04-04
- Description: Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding.
- Required Action: Apply updates per vendor instructions.
- Due Date: 2022-04-25
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2022-22965

A Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding. The specific exploit requires the application to run on Tomcat as a WAR deployment. If the application is deployed as a Spring Boot executable jar, i.e. the default, it is not vulnerable to the exploit. However, the nature of the vulnerability is more general, and there may be other ways to exploit it.

CWE-94 Improper Control of Generation of Code ('Code Injection')

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - US_GOVERNMENT_RESOURCE
- security@vmware.com - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2026-47884 suppress

Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/**" mapping that results in view rendering, and where the view name is not explicitly specified.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47891 suppress

A Spring WebFlux application that relies on the Aalto XML processor to parse XML input does not correctly enforce the maxInMemorySize limit.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59283 suppress

Applications that evaluate Spring Expression Language (SpEL) expressions using SimpleEvaluationContext may be vulnerable to a safety guard bypass when the SpEL expression compiler is active.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-913 Improper Control of Dynamically-Managed Code Resources

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2024-22259 suppress

Applications that use UriComponentsBuilder in Spring Framework to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks.

This is the same as CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.33
- ...

CVE-2021-22118 suppress

In Spring Framework, versions 5.2.x prior to 5.2.15 and versions 5.3.x prior to 5.3.7, a WebFlux application is vulnerable to a privilege escalation: by (re)creating the temporary storage directory, a locally authenticated malicious user can read or modify files that have been uploaded to the WebFlux application, or overwrite arbitrary files with multipart request data.

CWE-269 Improper Privilege Management, CWE-668 Exposure of Resource to Wrong Sphere

CVSSv3:
- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.6)
- Vector: /AV:L/AC:L/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.15
- ...

CVE-2026-47886 suppress

Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19

Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47888 suppress

A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE

CWE-401 Missing Release of Memory after Effective Lifetime

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.26
- ...

CVE-2026-47893 suppress

A Spring WebFlux application that supports WebSocket connections may expose indirectly sensitive user information by including request headers in an exception reason.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59282 suppress

Spring Framework applications that use Spring's data binding infrastructure to apply user-supplied property paths onto a target object may be vulnerable to a Denial of Service (DoS) attack.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2020-5421 suppress

In Spring Framework versions 5.2.0 - 5.2.8, 5.1.0 - 5.1.17, 5.0.0 - 5.0.18, 4.3.0 - 4.3.28, and older unsupported versions, the protections against RFD attacks from CVE-2015-5211 may be bypassed depending on the browser used through the use of a jsessionid path parameter.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:H/A:N/E:1.3/RC:R/MAV:A

CVSSv2:
- Base Score: LOW (3.6)
- Vector: /AV:N/AC:H/Au:S/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@pivotal.io - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - THIRD_PARTY_ADVISORY
- security@pivotal.io - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.9
- ...

CVE-2022-22950 suppress

n Spring Framework versions 5.3.0 - 5.3.16 and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial of service condition.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2022-22971 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, application with a STOMP over WebSocket endpoint is vulnerable to a denial of service attack by an authenticated user.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.21
- ...

CVE-2023-20861 suppress

In Spring Framework versions 6.0.0 - 6.0.6, 5.3.0 - 5.3.25, 5.2.0.RELEASE - 5.2.22.RELEASE, and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY

- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.22
- ...

CVE-2023-20863 suppress

In spring framework versions prior to 5.2.24 release+ ,5.3.27+ and 6.0.8+ , it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, CWE-917 Improper Neutralization of Special Elements used in an Expression Language Statement ('Expression Language Injection')

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.24
- ...

CVE-2026-22740 suppress

A WebFlux server application that processes multipart requests creates temp files for parts larger than 10 K. Under some circumstances, temp files may remain not deleted after the request is fully processed. This allows an attacker to consume available disk space.

Older, unsupported versions are also affected.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2026-47887 suppress

A Spring MVC application that uses UrlFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59281 suppress

Spring MVC and WebFlux applications that obtain a data-binding Errors instance with HTML escaping enabled and then render field errors using the no-argument Errors.getFieldErrors() or Errors.getFieldError() accessors are vulnerable to arbitrary HTML/JavaScript code injection, potentially resulting in a reflected cross-site scripting (XSS) vulnerability.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-22737 suppress

Use of Java scripting engine enabled (e.g. JRuby, Jython) template views in Spring MVC and Spring WebFlux applications can result in disclosure of content from files outside the configured locations for script template views. This issue affects Spring Framework: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

CVE-2022-22968 suppress

In Spring Framework versions 5.3.0 - 5.3.18, 5.2.0 - 5.2.20, and older unsupported versions, the patterns for disallowedFields on a DataBinder are case sensitive which means a field is not effectively protected unless it is listed with both upper and lower case for the first character of the field, including upper and lower case for the first character of all nested fields within the property path.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.20
- ...

CVE-2022-22970 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, applications that handle file uploads are vulnerable to DoS attack if they rely on data binding to set a MultipartFile or javax.servlet.Part to a field in a model object.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.6/RC:R/MAV:A

CVSSv2:
- Base Score: LOW (3.5)
- Vector: /AV:N/AC:M/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.21
- ...

CVE-2026-22745 suppress

Spring MVC and WebFlux applications are vulnerable to Denial of Service attacks when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

* the application is using Spring MVC or Spring WebFlux
* the application is serving static resources from the file system
* the application is running on a Windows platform

When all the conditions above are met, the attacker can send malicious requests that are slow to resolve and that can keep HTTP connections in use. This can cause a Denial of Service on the application.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2021-22060 suppress

In Spring Framework versions 5.3.0 - 5.3.13, 5.2.0 - 5.2.18, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries. This is a follow-up to CVE-2021-22096 that protects against additional types of input and in more places of the Spring Framework codebase.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.18
- ...

CVE-2021-22096 suppress

In Spring Framework versions 5.3.0 - 5.3.10, 5.2.0 - 5.2.17, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries.

CWE-117 Improper Output Neutralization for Logs, NVD-CWE-Other

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.17
- ...

CVE-2026-59280 suppress

Applications using Spring Framework's FreeMarker integration may be vulnerable to a path traversal attack when a controller returns a view name derived from untrusted input and FreeMarker is configured to resolve templates through SpringTemplateLoader.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-41839 suppress

A WebFlux application with a compromised subdomain (for example, compromised via cross-site scripting (XSS)) is vulnerable to an escalation attack exchanging a known session ID for that of an authenticated user.

Affected versions:
Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

CWE-384 Session Fixation

CVSSv3:
- Base Score: MEDIUM (4.2)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.49
- ...

CVE-2026-59314 suppress

Applications that build a Content-Disposition header value from untrusted input may be vulnerable to HTTP response splitting when the input is a malicious file name.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

NVD-CWE-Other, CWE-113 Improper Neutralization of CRLF Sequences in HTTP Headers ('HTTP Request/Response Splitting')

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.25
- ...

CVE-2026-22741 suppress

Spring MVC and WebFlux applications are vulnerable to cache poisoning when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

* the application is using Spring MVC or Spring WebFlux
* the application is configuring the resource chain support https://docs.spring.io/spring-framework/reference/web/webmvc/mvc-config/static-resources.html#page-title with caching enabled
* the application adds support for encoded resources resolution
* the resource cache must be empty when the attacker has access to the application

When all the conditions above are met, the attacker can send malicious requests and poison the resource cache with resources using the wrong encoding. This can cause a denial of service by breaking the front-end application for clients.

CWE-524 Use of Cache Containing Sensitive Information

CVSSv3:
- Base Score: LOW (3.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:L/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2026-22735 suppress

Spring MVC and WebFlux applications are vulnerable to stream corruption when using Server-Sent Events (SSE). This issue affects Spring Foundation: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-667 Improper Locking

CVSSv3:
- Base Score: LOW (2.6)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:N/E:1.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

spring-webmvc-5.2.3.RELEASE.jar

Description:

Spring Web MVC

License:

Apache License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0

File Path: C:\Users\Grace School\.m2\repository\org\springframework\spring-webmvc\5.2.3.RELEASE\spring-webmvc-5.2.3.RELEASE.jar
MD5: 867cc7369d453637b5042ee4d6931a78
SHA1: 745a62502023d2496b565b7fe102bb1ee229d6b7
SHA256:b3b0a2477e67b050dd5c08dc96e76db5950cbccba075e782c24f73eda49a0160
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.springframework/spring-webmvc@5.2.3.RELEASE (*Confidence*:High)
- cpe:2.3:a:pivotal_software:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:springsource:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:vmware:spring_framework:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:web_project:web:5.2.3:release:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2022-22965 suppress

CISA Known Exploited Vulnerability:

- Product: VMware Spring Framework
- Name: Spring Framework JDK 9+ Remote Code Execution Vulnerability
- Date Added: 2022-04-04
- Description: Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding.
- Required Action: Apply updates per vendor instructions.
- Due Date: 2022-04-25
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2022-22965

A Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding. The specific exploit requires the application to run on Tomcat as a WAR deployment. If the application is deployed as a Spring Boot executable jar, i.e. the default, it is not vulnerable to the exploit. However, the nature of the vulnerability is more general, and there may be other ways to exploit it.

CWE-94 Improper Control of Generation of Code ('Code Injection')

CVSSv3:

- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:

- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - US_GOVERNMENT_RESOURCE
- security@vmware.com - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2026-47884 suppress

Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/**" mapping that results in view rendering, and where the view name is not explicitly specified.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47891 suppress

A Spring WebFlux application that relies on the Aalto XML processor to parse XML input does not correctly enforce the maxInMemorySize limit.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59283 suppress

Applications that evaluate Spring Expression Language (SpEL) expressions using SimpleEvaluationContext may be vulnerable to a safety guard bypass when the SpEL expression compiler is active.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-913 Improper Control of Dynamically-Managed Code Resources

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2024-22259 suppress

Applications that use UriComponentsBuilder in Spring Framework to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks.

This is the same as CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.33
- ...

CVE-2021-22118 suppress

In Spring Framework, versions 5.2.x prior to 5.2.15 and versions 5.3.x prior to 5.3.7, a WebFlux application is vulnerable to a privilege escalation: by (re)creating the temporary storage directory, a locally authenticated malicious user can read or modify files that have been uploaded to the WebFlux application, or overwrite arbitrary files with multipart request data.

CWE-269 Improper Privilege Management, CWE-668 Exposure of Resource to Wrong Sphere

CVSSv3:

- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:

- Base Score: MEDIUM (4.6)
- Vector: /AV:L/AC:L/Au:N/C:P/I:P/A:P

References:

- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.15
- ...

CVE-2026-47886 suppress

Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-47888 suppress

A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE

CWE-401 Missing Release of Memory after Effective Lifetime

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.26
- ...

CVE-2026-47893 suppress

A Spring WebFlux application that supports WebSocket connections may expose indirectly sensitive user information by including request headers in an exception reason.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59282 suppress

Spring Framework applications that use Spring's data binding infrastructure to apply user-supplied property paths onto a target object may be vulnerable to a Denial of Service (DoS) attack.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2020-5421 suppress

In Spring Framework versions 5.2.0 - 5.2.8, 5.1.0 - 5.1.17, 5.0.0 - 5.0.18, 4.3.0 - 4.3.28, and older unsupported versions, the protections against RFD attacks from CVE-2015-5211 may be bypassed depending on the browser used through the use of a jsessionid path parameter.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:H/A:N/E:1.3/RC:R/MAV:A

CVSSv2:
- Base Score: LOW (3.6)
- Vector: /AV:N/AC:H/Au:S/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@pivotal.io - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - PATCH,THIRD_PARTY_ADVISORY
- security@pivotal.io - THIRD_PARTY_ADVISORY
- security@pivotal.io - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.9
- ...

CVE-2022-22950 suppress

n Spring Framework versions 5.3.0 - 5.3.16 and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial of service condition.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.20
- ...

CVE-2022-22971 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, application with a STOMP over WebSocket endpoint is vulnerable to a denial of service attack by an authenticated user.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.21
- ...

CVE-2023-20861 suppress

In Spring Framework versions 6.0.0 - 6.0.6, 5.3.0 - 5.3.25, 5.2.0.RELEASE - 5.2.22.RELEASE, and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.22
- ...

CVE-2023-20863 suppress

In spring framework versions prior to 5.2.24 release+ ,5.3.27+ and 6.0.8+ , it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

CWE-400 Uncontrolled Resource Consumption, CWE-917 Improper Neutralization of Special Elements used in an Expression Language Statement ('Expression Language Injection')

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (excluding) 5.2.24
- ...

CVE-2026-22740 suppress

A WebFlux server application that processes multipart requests creates temp files for parts larger than 10 K. Under some circumstances, temp files may remain not deleted after the request is fully processed. This allows an attacker to consume available disk space.

Older, unsupported versions are also affected.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2026-47887 suppress

A Spring MVC application that uses UrlFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-59281 suppress

Spring MVC and WebFlux applications that obtain a data-binding Errors instance with HTML escaping enabled and then render field errors using the no-argument Errors.getFieldErrors() or Errors.getFieldError() accessors are vulnerable to arbitrary HTML/JavaScript code injection, potentially resulting in a reflected cross-site scripting (XSS) vulnerability.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-22737 suppress

Use of Java scripting engine enabled (e.g. JRuby, Jython) template views in Spring MVC and Spring WebFlux applications can result in disclosure of content from files outside the configured locations for script template views. This issue affects Spring Framework: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

CVE-2022-22968 suppress

In Spring Framework versions 5.3.0 - 5.3.18, 5.2.0 - 5.2.20, and older unsupported versions, the patterns for disallowedFields on a DataBinder are case sensitive which means a field is not effectively protected unless it is listed with both upper and lower case for the first character of the field, including upper and lower case for the first character of all nested fields within the property path.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.20
- ...

CVE-2022-22970 suppress

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, applications that handle file uploads are vulnerable to DoS attack if they rely on data binding to set a MultipartFile or javax.servlet.Part to a field in a model object.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.6/RC:R/MAV:A

CVSSv2:

- Base Score: LOW (3.5)
- Vector: /AV:N/AC:M/Au:S/C:N/I:N/A:P

References:

- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@vmware.com - MITIGATION,VENDOR_ADVISORY
- security@vmware.com - PATCH,THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.21
- ...

CVE-2026-22745 suppress

Spring MVC and WebFlux applications are vulnerable to Denial of Service attacks when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

* the application is using Spring MVC or Spring WebFlux
* the application is serving static resources from the file system
* the application is running on a Windows platform

When all the conditions above are met, the attacker can send malicious requests that are slow to resolve and that can keep HTTP connections in use. This can cause a Denial of Service on the application.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2021-22060 suppress

In Spring Framework versions 5.3.0 - 5.3.13, 5.2.0 - 5.2.18, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries. This is a follow-up to CVE-2021-22096 that protects against additional types of input and in more places of the Spring Framework codebase.

NVD-CWE-noinfo

CVSSv3:

- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:

- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.18
- ...

CVE-2021-22096 suppress

In Spring Framework versions 5.3.0 - 5.3.10, 5.2.0 - 5.2.17, and older unsupported versions, it is possible for a user to provide malicious input to cause the insertion of additional log entries.

CWE-117 Improper Output Neutralization for Logs, NVD-CWE-Other

CVSSv3:

- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:

- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:N/I:P/A:N

References:

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - THIRD_PARTY_ADVISORY
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions from (including) 5.2.0; versions up to (including) 5.2.17
- ...

CVE-2026-59280 suppress

Applications using Spring Framework's FreeMarker integration may be vulnerable to a path traversal attack when a controller returns a view name derived from untrusted input and FreeMarker is configured to resolve templates through SpringTemplateLoader.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.2.26
- ...

CVE-2026-41839 suppress

A WebFlux application with a compromised subdomain (for example, compromised via cross-site scripting (XSS)) is vulnerable to an escalation attack exchanging a known session ID for that of an authenticated user.

Affected versions:
Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

CWE-384 Session Fixation

CVSSv3:
- Base Score: MEDIUM (4.2)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.49
- ...

CVE-2026-59314 suppress

Applications that build a Content-Disposition header value from untrusted input may be vulnerable to HTTP response splitting when the input is a malicious file name.
Spring Framework 7.0.0 - 7.0.8
Spring Framework 6.2.0 - 6.2.19
Spring Framework 6.1.0 - 6.1.28
Spring Framework 6.0.0 - 6.0.30
Spring Framework 5.3.0 - 5.3.49
Spring Framework 5.2.25.RELEASE and earlier

NVD-CWE-Other, CWE-113 Improper Neutralization of CRLF Sequences in HTTP Headers ('HTTP Request/Response Splitting')

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (including) 5.2.25
- ...

CVE-2026-22741 suppress

Spring MVC and WebFlux applications are vulnerable to cache poisoning when resolving static resources.

More precisely, an application can be vulnerable when all the following are true:

* the application is using Spring MVC or Spring WebFlux
* the application is configuring the resource chain support https://docs.spring.io/spring-framework/reference/web/webmvc/mvc-config/static-resources.html#page-title with caching enabled
* the application adds support for encoded resources resolution
* the resource cache must be empty when the attacker has access to the application

When all the conditions above are met, the attacker can send malicious requests and poison the resource cache with resources using the wrong encoding. This can cause a denial of service by breaking the front-end application for clients.

CWE-524 Use of Cache Containing Sensitive Information

CVSSv3:
- Base Score: LOW (3.1)

- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:L/E:1.6/RC:R/MAV:A

References:
- security@vmware.com - US_GOVERNMENT_RESOURCE
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.48
- ...

CVE-2026-22735 suppress

Spring MVC and WebFlux applications are vulnerable to stream corruption when using Server-Sent Events (SSE). This issue affects Spring Foundation: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-667 Improper Locking

CVSSv3:
- Base Score: LOW (2.6)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:N/E:1.2/RC:R/MAV:A

References:
- security@vmware.com - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:vmware:spring_framework:*:*:*:*:*:*:*:* versions up to (excluding) 5.3.47
- ...

tomcat-embed-core-9.0.30.jar

Description:

Core Tomcat implementation

License:

Apache License, Version 2.0: http://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\org\apache\tomcat\embed\tomcat-embed-core\9.0.30\tomcat-embed-core-9.0.30.jar
MD5: f9e49f66756f133157f19e617af26ffe
SHA1: ad32909314fe2ba02cec036434c0addd19bcc580
SHA256:b1415eecbc9f14e3745c1bfd41512a1b8e1af1332a7beaed4be30b2e0ba7b330
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@9.0.30 (*Confidence*:High)
- cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:apache_tomcat:apache_tomcat:9.0.30:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2020-1938 suppress

CISA Known Exploited Vulnerability:
- Product: Apache Tomcat
- Name: Apache Tomcat Improper Privilege Management Vulnerability
- Date Added: 2022-03-03
- Description: Apache Tomcat treats Apache JServ Protocol (AJP) connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited.
- Required Action: Apply updates per vendor instructions.
- Due Date: 2022-03-17
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2020-1938

When using the Apache JServ Protocol (AJP), care must be taken when trusting incoming connections to Apache Tomcat. Tomcat treats AJP connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited in ways that may be surprising. In Apache Tomcat 9.0.0.M1 to 9.0.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99, Tomcat shipped with an AJP Connector enabled by default that listened on all configured IP addresses. It was expected (and recommended in the security guide) that this Connector would be disabled if not required. This vulnerability report identified a mechanism that allowed: - returning arbitrary files from anywhere in the web application - processing any file in the web application as a JSP Further, if the web application allowed file upload and stored those files within the web application (or the attacker was able to control the content of the web application by some other means) then this, along with the ability to process a file as a JSP, made remote code execution possible. It is important to note that mitigation is only required if an AJP port is accessible to untrusted users. Users wishing to take a defence-in-depth approach and block the vector that permits returning arbitrary files and execution as JSP may upgrade to Apache Tomcat 9.0.31, 8.5.51 or 7.0.100 or later. A number of changes were made to the default AJP Connector configuration in 9.0.31 to harden the default configuration. It is likely that users upgrading to 9.0.31, 8.5.51 or 7.0.100 or later will need to make small changes to their configurations.

NVD-CWE-Other

CVSSv3:

- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:

- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 -

- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - RELEASE_NOTES
- security@apache.org - RELEASE_NOTES
- security@apache.org - RELEASE_NOTES
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.31
- ...

CVE-2024-50379 suppress

Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability during JSP compilation in Apache Tomcat permits an RCE on case insensitive file systems when the default servlet is enabled for write (non-default configuration).

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.0.97.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.2, 10.1.34 or 9.0.98, which fixes the issue.

CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2024-52316 suppress

Unchecked Error Condition vulnerability in Apache Tomcat. If Tomcat is configured to use a custom Jakarta Authentication (formerly JASPIC) ServerAuthContext component which may throw an exception during the authentication process without explicitly setting an HTTP status to indicate failure, the authentication may not fail, allowing the user to bypass the authentication process. There are no known Jakarta Authentication components that behave in this way.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M26, from 10.1.0-M1 through 10.1.30, from 9.0.0-M1 through 9.0.95.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0, 10.1.31 or 9.0.96, which fix the issue.

CWE-754 Improper Check for Unusual or Exceptional Conditions, CWE-391 Unchecked Error Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.96
- ...

CVE-2024-56337 suppress

Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.0.97.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

The mitigation for CVE-2024-50379 was incomplete.

Users running Tomcat on a case insensitive file system with the default servlet write enabled (readonly initialisation
parameter set to the non-default value of false) may need additional configuration to fully mitigate CVE-2024-50379 depending on which version of Java they are using with Tomcat:
- running on Java 8 or Java 11: the system property sun.io.useCanonCaches must be explicitly set to false (it defaults to true)
- running on Java 17: the system property sun.io.useCanonCaches, if set, must be set to false (it defaults to false)
- running on Java 21 onwards: no further configuration is required (the system property and the problematic cache have been removed)

Tomcat 11.0.3, 10.1.35 and 9.0.99 onwards will include checks that sun.io.useCanonCaches is set appropriately before allowing the default servlet to be write enabled on a case insensitive file system. Tomcat will also set sun.io.useCanonCaches to false by default where it can.

CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2025-24813 suppress

CISA Known Exploited Vulnerability:
- Product: Apache Tomcat
- Name: Apache Tomcat Path Equivalence Vulnerability
- Date Added: 2025-04-01
- Description: Apache Tomcat contains a path equivalence vulnerability that allows a remote attacker to execute code, disclose information, or inject malicious content via a partial PUT request. This vulnerability can be chained with CVE-2026-34486.
- Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.
- Due Date: 2025-04-22
- Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. Please check with specific vendors for information on patching status. For more information, please see: https://lists.apache.org/thread/j5fkjv2k477os90nczf2v9l61fb0kkgq ; https://nvd.nist.gov/vuln/detail/CVE-2025-24813

Path Equivalence: 'file.Name' (Internal Dot) leading to Remote Code Execution and/or Information disclosure and/or malicious content added to uploaded files via write enabled Default Servlet in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.2, from 10.1.0-M1 through 10.1.34, from 9.0.0.M1 through 9.0.98.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

If all of the following were true, a malicious user was able to view security sensitive files and/or inject content into those files:
- writes enabled for the default servlet (disabled by default)
- support for partial PUT (enabled by default)
- a target URL for security sensitive uploads that was a sub-directory of a target URL for public uploads
- attacker knowledge of the names of security sensitive files being uploaded
- the security sensitive files also being uploaded via partial PUT

If all of the following were true, a malicious user was able to perform remote code execution:
- writes enabled for the default servlet (disabled by default)
- support for partial PUT (enabled by default)
- application was using Tomcat's file based session persistence with the default storage location
- application included a library that may be leveraged in a deserialization attack

Users are recommended to upgrade to version 11.0.3, 10.1.35 or 9.0.99, which fixes the issue.

CWE-44 Path Equivalence: 'file.name' (Internal Dot), CWE-502 Deserialization of Untrusted Data, CWE-706 Use of Incorrectly-Resolved Name or Reference

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - EXPLOIT
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.99
- ...

CVE-2025-31651 suppress

Improper Neutralization of Escape, Meta, or Control Sequences vulnerability in Apache Tomcat. For a subset of unlikely rewrite rule configurations, it was possible for a specially crafted request to bypass some rewrite rules. If those
rewrite rules effectively enforced security constraints, those
constraints could be bypassed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.5, from 10.1.0-M1 through 10.1.39, from 9.0.0.M1 through 9.0.102.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-116 Improper Encoding or Escaping of Output

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.104
- ...

CVE-2026-41293 suppress

Improper Input Validation vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 10.0.0-M1 through 10.0.27.
Older, end of support versions may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-20 Improper Input Validation

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-43512 suppress

DEPRECATED: Authentication Bypass Issues vulnerability in digest authentication in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from before 7.0.0.
Older unsupported versions any also be affect

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-592 DEPRECATED: Authentication Bypass Issues

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-65905 suppress

Authentication Bypass by Capture-replay vulnerability in Apache Tomcat's DIGEST authenticator. If, before windowSize requests have been made, a client makes a DIGEST
authenticated request with a nonceCount on the upper boundary of the
replay window then that request is replayable once only while the
associated nonceCount remains within the replay window.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.30 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-294 Authentication Bypass by Capture-replay

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2025-66614 suppress

Improper Input Validation vulnerability.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.14, from 10.1.0-M1 through 10.1.49, from 9.0.0-M1 through 9.0.112.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Older EOL versions are not affected.
Tomcat did not validate that the host name provided via the SNI
extension was the same as the host name provided in the HTTP host header
field. If Tomcat was configured with more than one virtual host and the
TLS configuration for one of those hosts did not require client
certificate authentication but another one did, it was possible for a
client to bypass the client certificate authentication by sending
different host names in the SNI extension and the HTTP host header field.

The vulnerability only applies if client certificate authentication is
only enforced at the Connector. It does not apply if client certificate
authentication is enforced at the web application.

Users are recommended to upgrade to version 11.0.15 or later, 10.1.50 or later or 9.0.113 or later, which fix the issue.

CWE-20 Improper Input Validation, CWE-295 Improper Certificate Validation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.113
- ...

CVE-2026-43515 suppress

Improper Authorization vulnerability when multiple method constraints define an HTTP method for the same extension in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-55276 suppress

Always-Incorrect Control Flow Implementation vulnerability in Apache Tomcat meant that special roles and empty authorisation constraints were not included when the effective web.xml was logged.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119 which fixes the issue.

CWE-670 Always-Incorrect Control Flow Implementation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2026-59083 suppress

Improper Handling of URL Encoding (Hex Encoding) vulnerability in Apache Tomcat's rewrite valve allowed security constraint bypass for some configurations.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.23, from 10.1.0-M1 through 10.1.56, from 9.0.0.M1 through 9.0.119, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.24, 10.1.57 or 9.0.120, which fix the issue.

CWE-177 Improper Handling of URL Encoding (Hex Encoding)

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.119
- ...

CVE-2026-59084 suppress

Insufficient Technical Documentation vulnerability in Apache Tomcat since the requirements to securely configure the EncryptInterceptor were not clearly documented.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.23, from 10.1.0-M1 through 10.1.56, from 9.0.13 through 9.0.119, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.24, 10.1.57 or 9.0.120 which fix the issue.

CWE-1059 Insufficient Technical Documentation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (including) 9.0.119
- ...

CVE-2026-65182 suppress

Improper Access Control, Incorrect Authorization vulnerability in Apache Tomcat leads to security constraint bypass if a constraint for a longer path is specified before a more restrictive constraint for a shorter sub-path.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.25, 10.1.58, 9.0.121, which fixes the issue.

CWE-863 Incorrect Authorization, CWE-284 Improper Access Control

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2026-68525 suppress

Incorrect Authorization vulnerability in Apache Tomcat's FORM authentication process allows the bypassing of a security constraint that limits user has access to a resource POST but not GET.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fixes the issue.

CWE-863 Incorrect Authorization

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2025-49124 suppress

Untrusted Search Path vulnerability in Apache Tomcat installer for Windows. During installation, the Tomcat installer for Windows used icacls.exe without specifying a full path.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0 through 10.1.41, from 9.0.23 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100 and 7.0.95 through 7.0.109. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-426 Untrusted Search Path

CVSSv3:
- Base Score: HIGH (8.4)
- Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.5/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.23; versions up to (excluding) 9.0.106
- ...

CVE-2026-66422 suppress

Improper Authorization vulnerability in Apache Tomcat cause by security-role-ref definitions being incorrectly used as role aliases within the Realm in additional to the correct usage with Request.isUserInRole().

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.25 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.46 through 8.5.100, from 7.0.97 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.46; versions up to (excluding) 9.0.121
- ...

CVE-2026-68569 suppress

Improper Authentication vulnerability in Apache Tomcat meant that in some circumstances (e.g. CLIENT-CERT, SPNEGO) that a user would be authenticated even if the user did not exist in the DataSourceRealm.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-287 Improper Authentication

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2020-11996 suppress

A specially crafted sequence of HTTP/2 requests sent to Apache Tomcat 10.0.0-M1 to 10.0.0-M5, 9.0.0.M1 to 9.0.35 and 8.5.0 to 8.5.55 could trigger high CPU usage for several seconds. If a sufficient number of such requests were made on concurrent HTTP/2 connections, the server could become unresponsive.

NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.35
- ...

CVE-2020-13934 suppress

An h2c direct connection to Apache Tomcat 10.0.0-M1 to 10.0.0-M6, 9.0.0.M5 to 9.0.36 and 8.5.1 to 8.5.56 did not release the HTTP/1.1 processor after the upgrade to HTTP/2. If a sufficient number of such requests were made, an OutOfMemoryException could occur leading to a denial of service.

CWE-401 Missing Release of Memory after Effective Lifetime, CWE-476 NULL Pointer Dereference

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.36
- ...

CVE-2020-13935 suppress

The payload length in a WebSocket frame was not correctly validated in Apache Tomcat 10.0.0-M1 to 10.0.0-M6, 9.0.0.M1 to 9.0.36, 8.5.0 to 8.5.56 and 7.0.27 to 7.0.104. Invalid payload lengths could trigger an infinite loop. Multiple requests with invalid payload lengths could lead to a denial of service.

CWE-835 Loop with Unreachable Exit Condition ('Infinite Loop')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.36
- ...

CVE-2020-17527 suppress

While investigating bug 64830 it was discovered that Apache Tomcat 10.0.0-M1 to 10.0.0-M9, 9.0.0-M1 to 9.0.39 and 8.5.0 to 8.5.59 could re-use an HTTP request header value from the previous stream received on an HTTP/2 connection for the request associated with the subsequent stream. While this would most likely lead to an error and the closure of the HTTP/2 connection, it is possible that information could leak between requests.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.35
- ...

CVE-2021-25122 suppress

When responding to new h2c connection requests, Apache Tomcat versions 10.0.0-M1 to 10.0.0, 9.0.0.M1 to 9.0.41 and 8.5.0 to 8.5.61 could duplicate request headers and a limited amount of request body from one request to another meaning user A and user B could both see the results of user A's request.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.41
- ...

CVE-2021-41079 suppress

Apache Tomcat 8.5.0 to 8.5.63, 9.0.0-M1 to 9.0.43 and 10.0.0-M1 to 10.0.2 did not properly validate incoming TLS packets. When Tomcat was configured to use NIO+OpenSSL or NIO2+OpenSSL for TLS, a specially crafted packet could be used to trigger an infinite loop resulting in a denial of service.

CWE-20 Improper Input Validation, CWE-835 Loop with Unreachable Exit Condition ('Infinite Loop')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.44
- ...

CVE-2022-29885 suppress

The documentation of Apache Tomcat 10.1.0-M1 to 10.1.0-M14, 10.0.0-M1 to 10.0.20, 9.0.13 to 9.0.62 and 8.5.38 to 8.5.78 for the EncryptInterceptor incorrectly stated it enabled Tomcat clustering to run over an untrusted network. This was not correct. While the EncryptInterceptor does provide confidentiality and integrity protection, it does not protect against all risks associated with running over any untrusted network, particularly DoS risks.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:

- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:

- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,MITIGATION,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (including) 9.0.62
- ...

CVE-2022-42252 suppress

If Apache Tomcat 8.5.0 to 8.5.82, 9.0.0-M1 to 9.0.67, 10.0.0-M1 to 10.0.26 or 10.1.0-M1 to 10.1.0 was configured to ignore invalid HTTP headers via setting rejectIllegalHeader to false (the default for 8.5.x only), Tomcat did not reject a request containing an invalid Content-Length header making a request smuggling attack possible if Tomcat was located behind a reverse proxy that also failed to reject the request with the invalid header.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.68
- ...

CVE-2023-44487 suppress

CISA Known Exploited Vulnerability:

- Product: IETF HTTP/2
- Name: HTTP/2 Rapid Reset Attack Vulnerability
- Date Added: 2023-10-10
- Description: HTTP/2 contains a rapid reset vulnerability that allows for a distributed denial-of-service attack (DDoS).
- Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.
- Due Date: 2023-10-31
- Notes: This vulnerability affects a common open-source component, third-party library, or protocol used by different products. For more information, please see: HTTP/2 Rapid Reset Vulnerability, CVE-2023-44487 | CISA: https://www.cisa.gov/news-events/alerts/2023/10/10/http2-rapid-reset-vulnerability-cve-2023-44487; https://blog.cloudflare.com/technical-breakdown-http2-rapid-reset-ddos-attack/; https://nvd.nist.gov/vuln/detail/CVE-2023-44487

The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING

- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 -

- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,VENDOR_ADVISORY
- cve@mitre.org - MAILING_LIST,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,PATCH,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,PATCH,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,VENDOR_ADVISORY
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH,VENDOR_ADVISORY
- cve@mitre.org - PATCH,VENDOR_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRODUCT
- cve@mitre.org - PRODUCT
- cve@mitre.org - PRODUCT,RELEASE_NOTES
- cve@mitre.org - PRODUCT,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES
- cve@mitre.org - RELEASE_NOTES
- cve@mitre.org - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- cve@mitre.org - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.80
- ...

CVE-2023-46589 suppress

Improper Input Validation vulnerability in Apache Tomcat.Tomcat from 11.0.0-M1 through 11.0.0-M10, from 10.1.0-M1 through 10.1.15, from 9.0.0-M1 through 9.0.82 and from 8.5.0 through 8.5.95 did not correctly parse HTTP trailer headers. A trailer header that exceeded the header size limit could cause Tomcat to treat a single request as multiple requests leading to the possibility of request
smuggling when behind a reverse proxy.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M11 onwards, 10.1.16 onwards, 9.0.83 onwards or 8.5.96 onwards, which fix the issue.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY

- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.83
- ...

CVE-2024-24549 suppress

Denial of Service due to improper input validation vulnerability for HTTP/2 requests in Apache Tomcat. When processing an HTTP/2 request, if the request exceeded any of the configured limits for headers, the associated HTTP/2 stream was not reset until after all of the headers had been processed.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M16, from 10.1.0-M1 through 10.1.18, from 9.0.0-M1 through 9.0.85, from 8.5.0 through 8.5.98. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M17, 10.1.19, 9.0.86 or 8.5.99 which fix the issue.

CWE-20 Improper Input Validation, NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.86
- ...

CVE-2024-34750 suppress

Improper Handling of Exceptional Conditions, Uncontrolled Resource Consumption vulnerability in Apache Tomcat. When processing an HTTP/2 stream, Tomcat did not handle some cases of excessive HTTP headers correctly. This led to a miscounting of active HTTP/2 streams which in turn led to the use of an incorrect infinite timeout which allowed connections to remain open which should have been closed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M20, from 10.1.0-M1 through 10.1.24, from 9.0.0-M1 through 9.0.89.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M21, 10.1.25 or 9.0.90, which fixes the issue.

CWE-400 Uncontrolled Resource Consumption, CWE-755 Improper Handling of Exceptional Conditions

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.90
- ...

CVE-2024-38286 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M20, from 10.1.0-M1 through 10.1.24, from 9.0.13 through 9.0.89.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.35 through 8.5.100 and 7.0.92 through 7.0.109. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M21, 10.1.25, or 9.0.90, which fixes the issue.

Apache Tomcat, under certain configurations on any platform, allows an attacker to cause an OutOfMemoryError by abusing the TLS handshake process.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.90

- ...

CVE-2025-48988 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.106
- ...

CVE-2025-48989 suppress

Improper Resource Shutdown or Release vulnerability in Apache Tomcat made Tomcat vulnerable to the made you reset attack.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.9, from 10.1.0-M1 through 10.1.43 and from 9.0.0.M1 through 9.0.107. Older, EOL versions may also be affected.

Users are recommended to upgrade to one of versions 11.0.10, 10.1.44 or 9.0.108 which fix the issue.

CWE-404 Improper Resource Shutdown or Release

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.108
- ...

CVE-2025-49125 suppress

Authentication Bypass Using an Alternate Path or Channel vulnerability in Apache Tomcat. When using PreResources or PostResources mounted other than at the root of the web application, it was possible to access those resources via an unexpected path. That path was likely not to be protected by the same security constraints as the expected path, allowing those security constraints to be bypassed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.106
- ...

CVE-2025-52434 suppress

Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') vulnerability in Apache Tomcat when using the APR/Native connector. This was particularly noticeable with client initiated closes of HTTP/2 connections.

This issue affects Apache Tomcat: from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 9.0.107, which fixes the issue.

CWE-362 Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.107

CVE-2025-52520 suppress

For some unlikely configurations of multipart upload, an Integer Overflow vulnerability in Apache Tomcat could lead to a DoS via bypassing of size limits.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.8, from 10.1.0-M1 through 10.1.42, from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.9, 10.1.43 or 9.0.107, which fix the issue.

CWE-190 Integer Overflow or Wraparound

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.107
- ...

CVE-2025-53506 suppress

Uncontrolled Resource Consumption vulnerability in Apache Tomcat if an HTTP/2 client did not acknowledge the initial settings frame that reduces the maximum permitted concurrent streams.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.8, from 10.1.0-M1 through 10.1.42, from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.9, 10.1.43 or 9.0.107, which fix the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.106
- ...

CVE-2025-55752 suppress

Relative Path Traversal vulnerability in Apache Tomcat.

The fix for bug 60013 introduced a regression where the rewritten URL was normalized before it was decoded. This introduced the possibility that, for rewrite rules that rewrite query parameters to the URL, an attacker could manipulate the request URI to bypass security constraints including the protection for /WEB-INF/ and /META-INF/. If PUT requests were also enabled then malicious files could be uploaded leading to remote code execution. PUT requests are normally limited to trusted users and it is considered unlikely that PUT requests would be enabled in conjunction with a rewrite that manipulated the URI.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.10, from 10.1.0-M1 through 10.1.44, from 9.0.0.M11 through 9.0.108.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.6 though 8.5.100. Other, older, EOL versions may also be affected.
Users are recommended to upgrade to version 11.0.11 or later, 10.1.45 or later or 9.0.109 or later, which fix the issue.

CWE-23 Relative Path Traversal

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.109
- ...

CVE-2026-24880 suppress

Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in Apache Tomcat via invalid chunk extension.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0.M1 through 9.0.115, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.
Other, unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.20, 10.1.52 or 9.0.116, which fix the issue.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.116
- ...

CVE-2026-29146 suppress

Padding Oracle vulnerability in Apache Tomcat's EncryptInterceptor with default configuration.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.0.0-M1 through 10.1.52, from 9.0.13 through 9..115, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109.

Users are recommended to upgrade to version 11.0.19, 10.1.53 and 9.0.116, which fixes the issue.

CWE-642 External Control of Critical State Data, CWE-1240 Use of a Cryptographic Primitive with a Risky Implementation, CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.116
- ...

CVE-2026-34487 suppress

Insertion of Sensitive Information into Log File vulnerability in the cloud membership for clustering component of Apache Tomcat exposed the Kubernetes bearer token.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.20, from 10.1.0-M1 through 10.1.53, from 9.0.13 through 9.0.116.

Users are recommended to upgrade to version 11.0.21, 10.1.54 or 9.0.117, which fix the issue.

CWE-532 Insertion of Sensitive Information into Log File

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.117
- ...

CVE-2026-41284 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117.
Older, unsupported versions may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-43513 suppress

Improper Handling of Case Sensitivity vulnerability in LockOutRealm in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.
Older unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-65927 suppress

Off-by-one Error vulnerability in Apache Tomcat impacting the [N] flag on the rewrite valves causes rewrite processing to restart at the second rule rather than the first rule.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121 which fix the issue.

CWE-193 Off-by-one Error

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2026-68763 suppress

Uncontrolled Resource Consumption vulnerability in Apache Tomcat via an allocation leak in the HTTP/2 backlog tracking when a stream is reset

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.39 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.59 through 8.5.100. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.59; versions up to (excluding) 9.0.121
- ...

CVE-2025-46701 suppress

Improper Handling of Case Sensitivity vulnerability in Apache Tomcat's GCI servlet allows security constraint bypass of security constraints that apply to the pathInfo component of a URI mapped to the CGI servlet.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.6, from 10.1.0-M1 through 10.1.40, from 9.0.0.M1 through 9.0.104.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.7, 10.1.41 or 9.0.105, which fixes the issue.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.105
- ...

CVE-2026-42498 suppress

Exposure of HTTP Authentication Header to unexpected hosts during WebSocket authentication vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.2 through 9.0.117, from 8.5.24 through 8.5.100, from 7.0.83 through 7.0.109.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118, which fix the issue.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-53404 suppress

Always-Incorrect Control Flow Implementation vulnerability in Apache Tomcat's rewrite valve meant that if the first condition in an OR chain matched, subsequent non-OR conditions were skipped.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-670 Always-Incorrect Control Flow Implementation

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.119
- ...

CVE-2026-55957 suppress

Missing Critical Step in Authentication vulnerability in Apache Tomcat when the JNDIRealm was configured to authenticate binds using GSSAPI allowed attackers to authenticate without provided the correct password.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.4, from 10.1.0-M1 through 10.1.36, from 9.0.0.M1 through 9.0.100, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.5, 10.1.37 or 9.0.101, which fixes the issue.

CWE-304 Missing Critical Step in Authentication

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.101
- ...

CVE-2020-9484 suppress

When using Apache Tomcat versions 10.0.0-M1 to 10.0.0-M4, 9.0.0.M1 to 9.0.34, 8.5.0 to 8.5.54 and 7.0.0 to 7.0.103 if a) an attacker is able to control the contents and name of a file on the server; and b) the server is configured to use the PersistenceManager with a FileStore; and c) the PersistenceManager is configured with sessionAttributeValueClassNameFilter="null" (the default unless a SecurityManager is used) or a sufficiently lax filter to allow the attacker provided object to be deserialized; and d) the attacker knows the relative file path from the storage location used by FileStore to the file the attacker has control over; then, using a specifically crafted request, the attacker will be able to trigger remote code execution via deserialization of the file under their control. Note that all of conditions a) to d) must be true for the attack to succeed.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.4)
- Vector: /AV:L/AC:M/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- security@apache.org - MAILING_LIST,MITIGATION,PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.43
- ...

CVE-2021-25329 suppress

The fix for CVE-2020-9484 was incomplete. When using Apache Tomcat 10.0.0-M1 to 10.0.0, 9.0.0.M1 to 9.0.41, 8.5.0 to 8.5.61 or 7.0.0. to 7.0.107 with a configuration edge case that was highly unlikely to be used, the Tomcat instance was still vulnerable to CVE-2020-9494. Note that both the previously published prerequisites for CVE-2020-9484 and the previously published mitigations for CVE-2020-9484 also apply to this issue.

NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.4)
- Vector: /AV:L/AC:M/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY

- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.41
- ...

CVE-2026-73180 suppress

Insufficient Session Expiration vulnerability in Apache Tomcat meant that if the session ID for an authenticated HTTP session was changed after a WebSocket connection had been established under that authenticated HTTP session, the WebSokcet session would not be closed as required by the Jakarta WebSocket specification when the HTTP session ended.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.43 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-613 Insufficient Session Expiration

CVSSv3:
- Base Score: MEDIUM (6.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2021-30640 suppress

A vulnerability in the JNDI Realm of Apache Tomcat allows an attacker to authenticate using variations of a valid user name and/or to bypass some of the protection provided by the LockOut Realm. This issue affects Apache Tomcat 10.0.0-M1 to 10.0.5; 9.0.0.M1 to 9.0.45; 8.5.0 to 8.5.65.

CWE-116 Improper Encoding or Escaping of Output

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.46
- ...

CVE-2025-55668 suppress

Session Fixation vulnerability in Apache Tomcat via rewrite valve.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-384 Session Fixation

CVSSv3:
- Base Score: MEDIUM (6.5)

- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.106
- ...

CVE-2026-55955 suppress

Improper Authentication vulnerability in Apache Tomcat allowed a replay attack against the EncryptionInterceptor in the cluster component.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.13 through 9.0.18, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109.

Users are recommended to upgrade to version 11.0.23, 10.1.56, 9.0.119, which fixes the issue.

CWE-287 Improper Authentication

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2026-55956 suppress

Improper Authorization vulnerability in Apache Tomcat leads to security constraints specified for the default servlet ignoring any method or method omission configured as part of the constraint.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2024-23672 suppress

Denial of Service via incomplete cleanup vulnerability in Apache Tomcat. It was possible for WebSocket clients to keep WebSocket connections open leading to increased resource consumption.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M16, from 10.1.0-M1 through 10.1.18, from 9.0.0-M1 through 9.0.85, from 8.5.0 through 8.5.98.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M17, 10.1.19, 9.0.86 or 8.5.99 which fix the issue.

CWE-459 Incomplete Cleanup

CVSSv3:
- Base Score: MEDIUM (6.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.86
- ...

CVE-2022-34305 suppress

In Apache Tomcat 10.1.0-M1 to 10.1.0-M16, 10.0.0-M1 to 10.0.22, 9.0.30 to 9.0.64 and 8.5.50 to 8.5.81 the Form authentication example in the examples web application displayed user provided data without filtering, exposing a XSS vulnerability.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.30; versions up to (including) 9.0.64
- ...

CVE-2023-41080 suppress

URL Redirection to Untrusted Site ('Open Redirect') vulnerability in FORM authentication feature Apache Tomcat.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M10, from 10.1.0-M1 through 10.0.12, from 9.0.0-M1 through 9.0.79 and from 8.5.0 through 8.5.92.
Older, EOL versions may also be affected.

The vulnerability is limited to the ROOT (default) web application.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.79
- ...

CVE-2026-25854 suppress

Occasional URL redirection to untrusted Site ('Open Redirect') vulnerability in Apache Tomcat via the LoadBalancerDrainingValve.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0.M23 through 9.0.115, from 8.5.30 through 8.5.100.
Other, unsupported versions may also be affected

Users are recommended to upgrade to version 11.0.20, 10.1.53 or 9.0.116, which fix the issue.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.116
- ...

CVE-2026-50229 suppress

Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS) vulnerability in the number guess example for Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-80 Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.119

- ...

CVE-2021-24122 suppress

When serving resources from a network location using the NTFS file system, Apache Tomcat versions 10.0.0-M1 to 10.0.0-M9, 9.0.0.M1 to 9.0.39, 8.5.0 to 8.5.59 and 7.0.0 to 7.0.106 were susceptible to JSP source code disclosure in some configurations. The root cause was the unexpected behaviour of the JRE API File.getCanonicalPath() which in turn was caused by the inconsistent behaviour of the Windows API (FindFirstFileW) in some circumstances.

CWE-706 Use of Incorrectly-Resolved Name or Reference, CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.39
- ...

CVE-2021-33037 suppress

Apache Tomcat 10.0.0-M1 to 10.0.6, 9.0.0.M1 to 9.0.46 and 8.5.0 to 8.5.66 did not correctly parse the HTTP transfer-encoding request header in some circumstances leading to the possibility to request smuggling when used with a reverse proxy. Specifically: - Tomcat incorrectly ignored the transfer encoding header if the client declared it would only accept an HTTP/1.0 response; - Tomcat honoured the identify encoding; and - Tomcat did not ensure that, if present, the chunked encoding was the final encoding.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (excluding) 9.0.0; versions up to (including) 9.0.46
- ...

CVE-2023-42795 suppress

Incomplete Cleanup vulnerability in Apache Tomcat.When recycling various internal objects in Apache Tomcat from 11.0.0-M1 through 11.0.0-M11, from 10.1.0-M1 through 10.1.13, from 9.0.0-M1 through 9.0.80 and from 8.5.0 through 8.5.93, an error could
cause Tomcat to skip some parts of the recycling process leading to
information leaking from the current request/response to the next.
Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M12 onwards, 10.1.14 onwards, 9.0.81 onwards or 8.5.94 onwards, which fixes the issue.

CWE-459 Incomplete Cleanup

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.81
- ...

CVE-2023-45648 suppress

Improper Input Validation vulnerability in Apache Tomcat.Tomcat from 11.0.0-M1 through 11.0.0-M11, from 10.1.0-M1 through 10.1.13, from 9.0.0-M1 through 9.0.81 and from 8.5.0 through 8.5.93 did not correctly parse HTTP trailer headers. A specially crafted, invalid trailer header could cause Tomcat to treat a single request as multiple requests leading to the possibility of request smuggling when behind a reverse proxy.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M12 onwards, 10.1.14 onwards, 9.0.81 onwards or 8.5.94 onwards, which fix the issue.

CWE-20 Improper Input Validation, NVD-CWE-Other

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.81
- ...

CVE-2024-21733 suppress

Generation of Error Message Containing Sensitive Information vulnerability in Apache Tomcat.This issue affects Apache Tomcat: from 8.5.7 through 8.5.63, from 9.0.0-M11 through 9.0.43. Other, EOL versions may also be affected.

Users are recommended to upgrade to version 8.5.64 onwards or 9.0.44 onwards, which contain a fix for the issue.

CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.44
- ...

CVE-2024-54677 suppress

Uncontrolled Resource Consumption vulnerability in the examples web application provided with Apache Tomcat leads to denial of service.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.9.97. The following versions were EOL at the time the CVE was created but are known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.2, 10.1.34 or 9.0.98, which fixes the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2025-61795 suppress

Improper Resource Shutdown or Release vulnerability in Apache Tomcat.

If an error occurred (including exceeding limits) during the processing of a multipart upload, temporary copies of the uploaded parts written to disc were not cleaned up immediately but left for the garbage collection process to delete. Depending on JVM settings, application memory usage and application load, it was possible that space for the temporary copies of uploaded parts would be filled faster than GC cleared it, leading to a DoS.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.11, from 10.1.0-M1 through 10.1.46, from 9.0.0.M1 through 9.0.109.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.
Users are recommended to upgrade to version 11.0.12 or later, 10.1.47 or later or 9.0.110 or later which fixes the issue.

CWE-404 Improper Resource Shutdown or Release

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.110
- ...

CVE-2019-17569 suppress

The refactoring present in Apache Tomcat 9.0.28 to 9.0.30, 8.5.48 to 8.5.50 and 7.0.98 to 7.0.99 introduced a regression. The result of the regression was that invalid Transfer-Encoding headers were incorrectly processed leading to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.28; versions up to (including) 9.0.30
- ...

CVE-2020-1935 suppress

In Apache Tomcat 9.0.0.M1 to 9.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99 the HTTP header parsing code used an approach to end-of-line parsing that allowed some invalid HTTP headers to be parsed as valid. This led to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY

- security@apache.org - BROKEN_LINK,MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.30
- ...

CVE-2020-13943 suppress

If an HTTP/2 client connecting to Apache Tomcat 10.0.0-M1 to 10.0.0-M7, 9.0.0.M1 to 9.0.37 or 8.5.0 to 8.5.57 exceeded the agreed maximum number of concurrent streams for a connection (in violation of the HTTP/2 protocol), it was possible that a subsequent request made on that connection could contain HTTP headers - including HTTP/2 pseudo headers - from a previous request rather than the intended headers. This could lead to users seeing responses for unexpected resources.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - BROKEN_LINK
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:*
- ...

CVE-2023-28708 suppress

When using the RemoteIpFilter with requests received from a reverse proxy via HTTP that include the X-Forwarded-Proto header set to https, session cookies created by Apache Tomcat 11.0.0-M1 to 11.0.0.-M2, 10.1.0-M1 to 10.1.5, 9.0.0-M1 to 9.0.71 and 8.5.0 to 8.5.85 did not include the secure attribute. This could result in the user agent transmitting the session cookie over an insecure channel.

Older, EOL versions may also be affected.

CWE-523 Unprotected Transport of Credentials

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (excluding) 9.0.0; versions up to (excluding) 9.0.72
- ...

CVE-2021-43980 suppress

The simplified implementation of blocking reads and writes introduced in Tomcat 10 and back-ported to Tomcat 9.0.47 onwards exposed a long standing (but extremely hard to trigger) concurrency bug in Apache Tomcat 10.1.0 to 10.1.0-M12, 10.0.0-M1 to 10.0.18, 9.0.0-M1 to 9.0.60 and 8.5.0 to 8.5.77 that could cause client connections to share an Http11Processor instance resulting in responses, or part responses, to be received by the wrong client.

CWE-362 Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.60
- ...

CVE-2026-24733 suppress

Improper Input Validation vulnerability in Apache Tomcat.

Tomcat did not limit HTTP/0.9 requests to the GET method. If a security constraint was configured to allow HEAD requests to a URI but deny GET requests, the user could bypass that constraint on GET requests by sending a (specification invalid) HEAD request using HTTP/0.9.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.14, from 10.1.0-M1 through 10.1.49, from 9.0.0.M1 through 9.0.112.

Older, EOL versions are also affected.

Users are recommended to upgrade to version 11.0.15 or later, 10.1.50 or later or 9.0.113 or later, which fixes the issue.

CWE-20 Improper Input Validation, NVD-CWE-noinfo

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.113
- ...

CVE-2026-43514 suppress

Observable Timing Discrepancy vulnerability when comparing AJP secret in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.
Older unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-208 Observable Timing Discrepancy

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

tomcat-embed-websocket-9.0.30.jar

Description:

Core Tomcat implementation

License:

Apache License, Version 2.0: http://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\Grace School\.m2\repository\org\apache\tomcat\embed\tomcat-embed-websocket\9.0.30\tomcat-embed-websocket-9.0.30.jar
MD5: 3b6e5bcc92cd9a6df4a17138ed4e011c
SHA1: 33157f6bc5bfd03380ebb5ac476db0600a04168d
SHA256:4ce32add19b34a80376edb1e1678c373cb720c28c7a0d37a4361bf659c2ea84c
Referenced In Project/Scope: rest-service:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@2.2.4.RELEASE

Evidence

Identifiers

- pkg:maven/org.apache.tomcat.embed/tomcat-embed-websocket@9.0.30 (*Confidence*:High)
- cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:* (*Confidence*:Highest) suppress
- cpe:2.3:a:apache_tomcat:apache_tomcat:9.0.30:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

Published Vulnerabilities

CVE-2020-1938 suppress

CISA Known Exploited Vulnerability:

- Product: Apache Tomcat
- Name: Apache Tomcat Improper Privilege Management Vulnerability
- Date Added: 2022-03-03
- Description: Apache Tomcat treats Apache JServ Protocol (AJP) connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited.
- Required Action: Apply updates per vendor instructions.
- Due Date: 2022-03-17
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2020-1938

When using the Apache JServ Protocol (AJP), care must be taken when trusting incoming connections to Apache Tomcat. Tomcat treats AJP connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited in ways that may be surprising. In Apache Tomcat 9.0.0.M1 to 9.0.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99, Tomcat shipped with an AJP Connector enabled by default that listened on all configured IP addresses. It was expected (and recommended in the security guide) that this Connector would be disabled if not required. This vulnerability report identified a mechanism that allowed: - returning arbitrary files from anywhere in the web application - processing any file in the web application as a JSP Further, if the web application allowed file upload and stored those files within the web application (or the attacker was able to control the content of the web application by some other means) then this, along with the ability to process a file as a JSP, made remote code execution possible. It is important to note that mitigation is only required if an AJP port is accessible to untrusted users. Users wishing to take a defence-in-depth approach and block the vector that permits returning arbitrary files and execution as JSP may upgrade to Apache Tomcat 9.0.31, 8.5.51 or 7.0.100 or later. A number of changes were made to the default AJP Connector configuration in 9.0.31 to harden the default configuration. It is likely that users upgrading to 9.0.31, 8.5.51 or 7.0.100 or later will need to make small changes to their configurations.

NVD-CWE-Other

CVSSv3:

- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

CVSSv2:

- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:N/C:P/I:P/A:P

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - EXPLOIT,MAILING_LIST
- security@apache.org - ISSUE_TRACKING,MAILING_LIST
- security@apache.org - ISSUE_TRACKING,MAILING_LIST
- security@apache.org - ISSUE_TRACKING,MAILING_LIST
- security@apache.org - ISSUE_TRACKING,MAILING_LIST
- security@apache.org - ISSUE_TRACKING,MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST

- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST
- security@apache.org - MAILING_LIST,PATCH
- security@apache.org - MAILING_LIST,PATCH
- security@apache.org - MAILING_LIST,PATCH
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - RELEASE_NOTES
- security@apache.org - RELEASE_NOTES
- security@apache.org - RELEASE_NOTES
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show less)

- cpe:2.3:a:apache:geode:1.12.0:*:*:*:*:*:*:*
- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 7.0.0; versions up to (excluding) 7.0.100
- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 8.5.51
- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.31
- cpe:2.3:a:blackberry:good_control:*:*:*:*:*:*:*:* versions up to (including) 5.2.58.38
- cpe:2.3:a:blackberry:workspaces_server:7.0.1:*:*:*:*:*:*:*
- cpe:2.3:a:blackberry:workspaces_server:7.1.2:*:*:*:*:*:*:*
- cpe:2.3:a:blackberry:workspaces_server:8.1.0:*:*:*:*:*:*:*
- cpe:2.3:a:blackberry:workspaces_server:9.0:*:*:*:*:*:*:*
- cpe:2.3:a:netapp:data_availability_services:-:*:*:*:*:*:*:*
- cpe:2.3:a:netapp:oncommand_system_manager:*:*:*:*:*:*:*:* versions from (including) 3.0.0; versions up to (including) 3.1.3
- cpe:2.3:a:oracle:agile_engineering_data_management:6.2.1.0:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:agile_product_lifecycle_management:9.3.3:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:agile_product_lifecycle_management:9.3.5:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:agile_product_lifecycle_management:9.3.6:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:communications_element_manager:8.1.1:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:communications_element_manager:8.2.0:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:communications_element_manager:8.2.1:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:communications_instant_messaging_server:10.0.1.4.0:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:health_sciences_empirica_inspections:1.0.1.2:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:health_sciences_empirica_signal:7.3.3:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:hospitality_guest_access:4.2.0:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:hospitality_guest_access:4.2.1:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:instantis_enterprisetrack:*:*:*:*:*:*:*:* versions from (including) 17.1; versions up to (including) 17.3
- cpe:2.3:a:oracle:mysql_enterprise_monitor:*:*:*:*:*:*:*:* versions up to (including) 4.0.12
- cpe:2.3:a:oracle:mysql_enterprise_monitor:*:*:*:*:*:*:*:* versions from (including) 8.0.0; versions up to (including) 8.0.20
- cpe:2.3:a:oracle:siebel_ui_framework:*:*:*:*:*:*:*:* versions up to (including) 20.5
- cpe:2.3:a:oracle:transportation_management:6.3.7:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:workload_manager:18c:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:workload_manager:19c:*:*:*:*:*:*:*
- cpe:2.3:a:oracle:workload_manager:12.2.0.1:*:*:*:*:*:*:*

CVE-2024-50379 suppress

Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability during JSP compilation in Apache Tomcat permits an RCE on case insensitive file systems when the default servlet is enabled for write (non-default configuration).

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.0.97.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.2, 10.1.34 or 9.0.98, which fixes the issue.

CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2024-52316 suppress

Unchecked Error Condition vulnerability in Apache Tomcat. If Tomcat is configured to use a custom Jakarta Authentication (formerly JASPIC) ServerAuthContext component which may throw an exception during the authentication process without explicitly setting an HTTP status to indicate failure, the authentication may not fail, allowing the user to bypass the authentication process. There are no known Jakarta Authentication components that behave in this way.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M26, from 10.1.0-M1 through 10.1.30, from 9.0.0-M1 through 9.0.95.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0, 10.1.31 or 9.0.96, which fix the issue.

CWE-754 Improper Check for Unusual or Exceptional Conditions, CWE-391 Unchecked Error Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.96
- ...

CVE-2024-56337 suppress

Time-of-check Time-of-use (TOCTOU) Race Condition vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.0.97.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

The mitigation for CVE-2024-50379 was incomplete.

Users running Tomcat on a case insensitive file system with the default servlet write enabled (readonly initialisation
parameter set to the non-default value of false) may need additional configuration to fully mitigate CVE-2024-50379 depending on which version of Java they are using with Tomcat:
- running on Java 8 or Java 11: the system property sun.io.useCanonCaches must be explicitly set to false (it defaults to true)
- running on Java 17: the system property sun.io.useCanonCaches, if set, must be set to false (it defaults to false)
- running on Java 21 onwards: no further configuration is required (the system property and the problematic cache have been removed)

Tomcat 11.0.3, 10.1.35 and 9.0.99 onwards will include checks that sun.io.useCanonCaches is set appropriately before allowing the default servlet to be write enabled on a case insensitive file system. Tomcat will also set sun.io.useCanonCaches to false by default where it can.

CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2025-24813 suppress

CISA Known Exploited Vulnerability:
- Product: Apache Tomcat
- Name: Apache Tomcat Path Equivalence Vulnerability
- Date Added: 2025-04-01
- Description: Apache Tomcat contains a path equivalence vulnerability that allows a remote attacker to execute code, disclose information, or inject malicious content via a partial PUT request. This vulnerability can be chained with CVE-2026-34486.
- Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.
- Due Date: 2025-04-22
- Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. Please check with specific vendors for information on patching status. For more information, please see: https://lists.apache.org/thread/j5fkjv2k477os90nczf2v9l61fb0kkgq ; https://nvd.nist.gov/vuln/detail/CVE-2025-24813

Path Equivalence: 'file.Name' (Internal Dot) leading to Remote Code Execution and/or Information disclosure and/or malicious content added to uploaded files via write enabled Default Servlet in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.2, from 10.1.0-M1 through 10.1.34, from 9.0.0.M1 through 9.0.98.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

If all of the following were true, a malicious user was able to view security sensitive files and/or inject content into those files:
- writes enabled for the default servlet (disabled by default)
- support for partial PUT (enabled by default)
- a target URL for security sensitive uploads that was a sub-directory of a target URL for public uploads
- attacker knowledge of the names of security sensitive files being uploaded
- the security sensitive files also being uploaded via partial PUT

If all of the following were true, a malicious user was able to perform remote code execution:
- writes enabled for the default servlet (disabled by default)
- support for partial PUT (enabled by default)
- application was using Tomcat's file based session persistence with the default storage location
- application included a library that may be leveraged in a deserialization attack

Users are recommended to upgrade to version 11.0.3, 10.1.35 or 9.0.99, which fixes the issue.

CWE-44 Path Equivalence: 'file.name' (Internal Dot), CWE-502 Deserialization of Untrusted Data, CWE-706 Use of Incorrectly-Resolved Name or Reference

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - EXPLOIT
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.99
- ...

CVE-2025-31651 suppress

Improper Neutralization of Escape, Meta, or Control Sequences vulnerability in Apache Tomcat. For a subset of unlikely rewrite rule configurations, it was possible for a specially crafted request to bypass some rewrite rules. If those
rewrite rules effectively enforced security constraints, those
constraints could be bypassed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.5, from 10.1.0-M1 through 10.1.39, from 9.0.0.M1 through 9.0.102.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-116 Improper Encoding or Escaping of Output

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.104
- ...

CVE-2026-41293 suppress

Improper Input Validation vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 10.0.0-M1 through 10.0.27.
Older, end of support versions may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-20 Improper Input Validation

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-43512 suppress

DEPRECATED: Authentication Bypass Issues vulnerability in digest authentication in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from before 7.0.0.
Older unsupported versions any also be affect

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-592 DEPRECATED: Authentication Bypass Issues

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-65905 suppress

Authentication Bypass by Capture-replay vulnerability in Apache Tomcat's DIGEST authenticator. If, before windowSize requests have been made, a client makes a DIGEST
authenticated request with a nonceCount on the upper boundary of the
replay window then that request is replayable once only while the
associated nonceCount remains within the replay window.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.30 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-294 Authentication Bypass by Capture-replay

CVSSv3:
- Base Score: CRITICAL (9.8)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2025-66614 suppress

Improper Input Validation vulnerability.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.14, from 10.1.0-M1 through 10.1.49, from 9.0.0-M1 through 9.0.112.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Older EOL versions are not affected.
Tomcat did not validate that the host name provided via the SNI
extension was the same as the host name provided in the HTTP host header
field. If Tomcat was configured with more than one virtual host and the
TLS configuration for one of those hosts did not require client
certificate authentication but another one did, it was possible for a
client to bypass the client certificate authentication by sending
different host names in the SNI extension and the HTTP host header field.

The vulnerability only applies if client certificate authentication is
only enforced at the Connector. It does not apply if client certificate
authentication is enforced at the web application.

Users are recommended to upgrade to version 11.0.15 or later, 10.1.50 or later or 9.0.113 or later, which fix the issue.

CWE-20 Improper Input Validation, CWE-295 Improper Certificate Validation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.113
- ...

CVE-2026-43515 suppress

Improper Authorization vulnerability when multiple method constraints define an HTTP method for the same extension in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-55276 suppress

Always-Incorrect Control Flow Implementation vulnerability in Apache Tomcat meant that special roles and empty authorisation constraints were not included when the effective web.xml was logged.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119 which fixes the issue.

CWE-670 Always-Incorrect Control Flow Implementation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2026-59083 suppress

Improper Handling of URL Encoding (Hex Encoding) vulnerability in Apache Tomcat's rewrite valve allowed security constraint bypass for some configurations.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.23, from 10.1.0-M1 through 10.1.56, from 9.0.0.M1 through 9.0.119, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.24, 10.1.57 or 9.0.120, which fix the issue.

CWE-177 Improper Handling of URL Encoding (Hex Encoding)

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.119
- ...

CVE-2026-59084 suppress

Insufficient Technical Documentation vulnerability in Apache Tomcat since the requirements to securely configure the EncryptInterceptor were not clearly documented.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.23, from 10.1.0-M1 through 10.1.56, from 9.0.13 through 9.0.119, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.24, 10.1.57 or 9.0.120 which fix the issue.

CWE-1059 Insufficient Technical Documentation

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MITIGATION,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (including) 9.0.119
- ...

CVE-2026-65182 suppress

Improper Access Control, Incorrect Authorization vulnerability in Apache Tomcat leads to security constraint bypass if a constraint for a longer path is specified before a more restrictive constraint for a shorter sub-path.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.25, 10.1.58, 9.0.121, which fixes the issue.

CWE-863 Incorrect Authorization, CWE-284 Improper Access Control

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2026-68525 suppress

Incorrect Authorization vulnerability in Apache Tomcat's FORM authentication process allows the bypassing of a security constraint that limits user has access to a resource POST but not GET.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fixes the issue.

CWE-863 Incorrect Authorization

CVSSv3:
- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2025-49124 suppress

Untrusted Search Path vulnerability in Apache Tomcat installer for Windows. During installation, the Tomcat installer for Windows used icacls.exe without specifying a full path.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0 through 10.1.41, from 9.0.23 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100 and 7.0.95 through 7.0.109. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-426 Untrusted Search Path

CVSSv3:
- Base Score: HIGH (8.4)
- Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.5/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.23; versions up to (excluding) 9.0.106
- ...

CVE-2026-66422 suppress

Improper Authorization vulnerability in Apache Tomcat cause by security-role-ref definitions being incorrectly used as role aliases within the Realm in additional to the correct usage with Request.isUserInRole().

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.25 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.46 through 8.5.100, from 7.0.97 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.46; versions up to (excluding) 9.0.121
- ...

CVE-2026-68569 suppress

Improper Authentication vulnerability in Apache Tomcat meant that in some circumstances (e.g. CLIENT-CERT, SPNEGO) that a user would be authenticated even if the user did not exist in the DataSourceRealm.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-287 Improper Authentication

CVSSv3:
- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2020-8022 suppress

A Incorrect Default Permissions vulnerability in the packaging of tomcat on SUSE Enterprise Storage 5, SUSE Linux Enterprise Server 12-SP2-BCL, SUSE Linux Enterprise Server 12-SP2-LTSS, SUSE Linux Enterprise Server 12-SP3-BCL, SUSE Linux Enterprise Server 12-SP3-LTSS, SUSE Linux Enterprise Server 12-SP4, SUSE Linux Enterprise Server 12-SP5, SUSE Linux Enterprise Server 15-LTSS, SUSE Linux Enterprise Server for SAP 12-SP2, SUSE Linux Enterprise Server for SAP

12-SP3, SUSE Linux Enterprise Server for SAP 15, SUSE OpenStack Cloud 7, SUSE OpenStack Cloud 8, SUSE OpenStack Cloud Crowbar 8 allows local attackers to escalate from group tomcat to root. This issue affects: SUSE Enterprise Storage 5 tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server 12-SP2-BCL tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server 12-SP2-LTSS tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server 12-SP3-BCL tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server 12-SP3-LTSS tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server 12-SP4 tomcat versions prior to 9.0.35-3.39.1. SUSE Linux Enterprise Server 12-SP5 tomcat versions prior to 9.0.35-3.39.1. SUSE Linux Enterprise Server 15-LTSS tomcat versions prior to 9.0.35-3.57.3. SUSE Linux Enterprise Server for SAP 12-SP2 tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server for SAP 12-SP3 tomcat versions prior to 8.0.53-29.32.1. SUSE Linux Enterprise Server for SAP 15 tomcat versions prior to 9.0.35-3.57.3. SUSE OpenStack Cloud 7 tomcat versions prior to 8.0.53-29.32.1. SUSE OpenStack Cloud 8 tomcat versions prior to 8.0.53-29.32.1. SUSE OpenStack Cloud Crowbar 8 tomcat versions prior to 8.0.53-29.32.1.

CWE-276 Incorrect Default Permissions

CVSSv3:
- Base Score: HIGH (7.8)
- Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.8/RC:R/MAV:A

CVSSv2:
- Base Score: HIGH (7.2)
- Vector: /AV:L/AC:L/Au:N/C:C/I:C/A:C

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,ISSUE_TRACKING,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- meissner@suse.de - EXPLOIT,ISSUE_TRACKING,VENDOR_ADVISORY
- meissner@suse.de - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.35-3.57.3
- ...

CVE-2020-11996 suppress

A specially crafted sequence of HTTP/2 requests sent to Apache Tomcat 10.0.0-M1 to 10.0.0-M5, 9.0.0.M1 to 9.0.35 and 8.5.0 to 8.5.55 could trigger high CPU usage for several seconds. If a sufficient number of such requests were made on concurrent HTTP/2 connections, the server could become unresponsive.

NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.35
- ...

CVE-2020-13934 suppress

An h2c direct connection to Apache Tomcat 10.0.0-M1 to 10.0.0-M6, 9.0.0.M5 to 9.0.36 and 8.5.1 to 8.5.56 did not release the HTTP/1.1 processor after the upgrade to HTTP/2. If a sufficient number of such requests were made, an OutOfMemoryException could occur leading to a denial of service.

CWE-401 Missing Release of Memory after Effective Lifetime, CWE-476 NULL Pointer Dereference

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY

- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.36
- ...

CVE-2020-13935 suppress

The payload length in a WebSocket frame was not correctly validated in Apache Tomcat 10.0.0-M1 to 10.0.0-M6, 9.0.0.M1 to 9.0.36, 8.5.0 to 8.5.56 and 7.0.27 to 7.0.104. Invalid payload lengths could trigger an infinite loop. Multiple requests with invalid payload lengths could lead to a denial of service.

CWE-835 Loop with Unreachable Exit Condition ('Infinite Loop')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - NOT_APPLICABLE,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.36
- ...

CVE-2020-17527 suppress

While investigating bug 64830 it was discovered that Apache Tomcat 10.0.0-M1 to 10.0.0-M9, 9.0.0-M1 to 9.0.39 and 8.5.0 to 8.5.59 could re-use an HTTP request header value from the previous stream received on an HTTP/2 connection for the request associated with the subsequent stream. While this would most likely lead to an error and the closure of the HTTP/2 connection, it is possible that information could leak between requests.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY

- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.35
- ...

CVE-2021-25122 suppress

When responding to new h2c connection requests, Apache Tomcat versions 10.0.0-M1 to 10.0.0, 9.0.0.M1 to 9.0.41 and 8.5.0 to 8.5.61 could duplicate request headers and a limited amount of request body from one request to another meaning user A and user B could both see the results of user A's request.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.41
- ...

CVE-2021-41079 suppress

Apache Tomcat 8.5.0 to 8.5.63, 9.0.0-M1 to 9.0.43 and 10.0.0-M1 to 10.0.2 did not properly validate incoming TLS packets. When Tomcat was configured to use NIO+OpenSSL or NIO2+OpenSSL for TLS, a specially crafted packet could be used to trigger an infinite loop resulting in a denial of service.

CWE-20 Improper Input Validation, CWE-835 Loop with Unreachable Exit Condition ('Infinite Loop')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.44
- ...

CVE-2022-29885 suppress

The documentation of Apache Tomcat 10.1.0-M1 to 10.1.0-M14, 10.0.0-M1 to 10.0.20, 9.0.13 to 9.0.62 and 8.5.38 to 8.5.78 for the EncryptInterceptor incorrectly stated it enabled Tomcat clustering to run over an untrusted network. This was not correct. While the EncryptInterceptor does provide confidentiality and integrity protection, it does not protect against all risks associated with running over any untrusted network, particularly DoS risks.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

CVSSv2:

- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:N/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,MITIGATION,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (including) 9.0.62
- ...

CVE-2022-42252 suppress

If Apache Tomcat 8.5.0 to 8.5.82, 9.0.0-M1 to 9.0.67, 10.0.0-M1 to 10.0.26 or 10.1.0-M1 to 10.1.1 was configured to ignore invalid HTTP headers via setting rejectIllegalHeader to false (the default for 8.5.x only), Tomcat did not reject a request containing an invalid Content-Length header making a request smuggling attack possible if Tomcat was located behind a reverse proxy that also failed to reject the request with the invalid header.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.68
- ...

CVE-2023-44487 suppress

CISA Known Exploited Vulnerability:
- Product: IETF HTTP/2
- Name: HTTP/2 Rapid Reset Attack Vulnerability
- Date Added: 2023-10-10
- Description: HTTP/2 contains a rapid reset vulnerability that allows for a distributed denial-of-service attack (DDoS).
- Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable.
- Due Date: 2023-10-31
- Notes: This vulnerability affects a common open-source component, third-party library, or protocol used by different products. For more information, please see: HTTP/2 Rapid Reset Vulnerability, CVE-2023-44487 | CISA: https://www.cisa.gov/news-events/alerts/2023/10/10/http2-rapid-reset-vulnerability-cve-2023-44487; https://blog.cloudflare.com/technical-breakdown-http2-rapid-reset-ddos-attack/; https://nvd.nist.gov/vuln/detail/CVE-2023-44487

The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.

CWE-400 Uncontrolled Resource Consumption, NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 0b142b55-0307-4c5a-b3c9-f314f3fb7c5e - THIRD_PARTY_ADVISORY
- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH

- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PRESS/MEDIA_COVERAGE
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH
- af854a3a-2127-422b-91ae-364da2661108 - PATCH
- af854a3a-2127-422b-91ae-364da2661108 - PATCH
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRESS/MEDIA_COVERAGE
- af854a3a-2127-422b-91ae-364da2661108 - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PRODUCT
- af854a3a-2127-422b-91ae-364da2661108 - PRODUCT
- af854a3a-2127-422b-91ae-364da2661108 - PRODUCT,RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - PRODUCT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 -

- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- cve@mitre.org - MAILING_LIST,VENDOR_ADVISORY
- cve@mitre.org - MAILING_LIST,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,PATCH,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,PATCH,VENDOR_ADVISORY
- cve@mitre.org - MITIGATION,VENDOR_ADVISORY
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH
- cve@mitre.org - PATCH,VENDOR_ADVISORY
- cve@mitre.org - PATCH,VENDOR_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRESS/MEDIA_COVERAGE,THIRD_PARTY_ADVISORY
- cve@mitre.org - PRODUCT
- cve@mitre.org - PRODUCT
- cve@mitre.org - PRODUCT,RELEASE_NOTES
- cve@mitre.org - PRODUCT,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES
- cve@mitre.org - RELEASE_NOTES
- cve@mitre.org - RELEASE_NOTES,THIRD_PARTY_ADVISORY
- cve@mitre.org - RELEASE_NOTES,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - TECHNICAL_DESCRIPTION,VENDOR_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- cve@mitre.org - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- cve@mitre.org - THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY
- cve@mitre.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.80
- ...

CVE-2023-46589 suppress

Improper Input Validation vulnerability in Apache Tomcat.Tomcat from 11.0.0-M1 through 11.0.0-M10, from 10.1.0-M1 through 10.1.15, from 9.0.0-M1 through 9.0.82 and from 8.5.0 through 8.5.95 did not correctly parse HTTP trailer headers. A trailer header that exceeded the header size limit could cause Tomcat to treat a single request as multiple requests leading to the possibility of request
smuggling when behind a reverse proxy.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M11 onwards, 10.1.16 onwards, 9.0.83 onwards or 8.5.96 onwards, which fix the issue.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.83

- ...

CVE-2024-24549 suppress

Denial of Service due to improper input validation vulnerability for HTTP/2 requests in Apache Tomcat. When processing an HTTP/2 request, if the request exceeded any of the configured limits for headers, the associated HTTP/2 stream was not reset until after all of the headers had been processed.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M16, from 10.1.0-M1 through 10.1.18, from 9.0.0-M1 through 9.0.85, from 8.5.0 through 8.5.98. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M17, 10.1.19, 9.0.86 or 8.5.99 which fix the issue.

CWE-20 Improper Input Validation, NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.86
- ...

CVE-2024-34750 suppress

Improper Handling of Exceptional Conditions, Uncontrolled Resource Consumption vulnerability in Apache Tomcat. When processing an HTTP/2 stream, Tomcat did not handle some cases of excessive HTTP headers correctly. This led to a miscounting of active HTTP/2 streams which in turn led to the use of an incorrect infinite timeout which allowed connections to remain open which should have been closed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M20, from 10.1.0-M1 through 10.1.24, from 9.0.0-M1 through 9.0.89.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M21, 10.1.25 or 9.0.90, which fixes the issue.

CWE-400 Uncontrolled Resource Consumption, CWE-755 Improper Handling of Exceptional Conditions

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.90
- ...

CVE-2024-38286 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M20, from 10.1.0-M1 through 10.1.24, from 9.0.13 through 9.0.89.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.35 through 8.5.100 and 7.0.92 through 7.0.109. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M21, 10.1.25, or 9.0.90, which fixes the issue.

Apache Tomcat, under certain configurations on any platform, allows an attacker to cause an OutOfMemoryError by abusing the TLS handshake process.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.90
- ...

CVE-2025-48988 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.106
- ...

CVE-2025-48989 suppress

Improper Resource Shutdown or Release vulnerability in Apache Tomcat made Tomcat vulnerable to the made you reset attack.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.9, from 10.1.0-M1 through 10.1.43 and from 9.0.0.M1 through 9.0.107. Older, EOL versions may also be affected.

Users are recommended to upgrade to one of versions 11.0.10, 10.1.44 or 9.0.108 which fix the issue.

CWE-404 Improper Resource Shutdown or Release

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.108
- ...

CVE-2025-49125 suppress

Authentication Bypass Using an Alternate Path or Channel vulnerability in Apache Tomcat. When using PreResources or PostResources mounted other than at the root of the web application, it was possible to access those resources via an unexpected path. That path was likely not to be protected by the same security constraints as the expected path, allowing those security constraints to be bypassed.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.106
- ...

CVE-2025-52434 suppress

Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') vulnerability in Apache Tomcat when using the APR/Native connector. This was particularly noticeable with client initiated closes of HTTP/2 connections.

This issue affects Apache Tomcat: from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 9.0.107, which fixes the issue.

CWE-362 Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions:

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.107

CVE-2025-52520 suppress

For some unlikely configurations of multipart upload, an Integer Overflow vulnerability in Apache Tomcat could lead to a DoS via bypassing of size limits.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.8, from 10.1.0-M1 through 10.1.42, from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other, older, EOL versions
may also be affected.

Users are recommended to upgrade to version 11.0.9, 10.1.43 or 9.0.107, which fix the issue.

CWE-190 Integer Overflow or Wraparound

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.107
- ...

CVE-2025-53506 suppress

Uncontrolled Resource Consumption vulnerability in Apache Tomcat if an HTTP/2 client did not acknowledge the initial settings frame that reduces the maximum permitted concurrent streams.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.8, from 10.1.0-M1 through 10.1.42, from 9.0.0.M1 through 9.0.106.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 through 8.5.100. Other EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.9, 10.1.43 or 9.0.107, which fix the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- security@apache.org - ISSUE_TRACKING,MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.106
- ...

CVE-2025-55752 suppress

Relative Path Traversal vulnerability in Apache Tomcat.

The fix for bug 60013 introduced a regression where the rewritten URL was normalized before it was decoded. This introduced the possibility that, for rewrite rules that rewrite query parameters to the URL, an attacker could manipulate the request URI to bypass security constraints including the protection for /WEB-INF/ and /META-INF/. If PUT requests were also enabled then malicious files could be uploaded leading to remote code execution. PUT requests are normally limited to trusted users and it is considered unlikely that PUT requests would be enabled in conjunction with a rewrite that manipulated the URI.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.10, from 10.1.0-M1 through 10.1.44, from 9.0.0.M11 through 9.0.108.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.6 though 8.5.100. Other, older, EOL versions may also be affected.
Users are recommended to upgrade to version 11.0.11 or later, 10.1.45 or later or 9.0.109 or later, which fix the issue.

CWE-23 Relative Path Traversal

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MITIGATION,THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.109
- ...

CVE-2026-24880 suppress

Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in Apache Tomcat via invalid chunk extension.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0.M1 through 9.0.115, from 8.5.0 through 8.5.100, from

7.0.0 through 7.0.109.
Other, unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.20, 10.1.52 or 9.0.116, which fix the issue.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.116
- ...

CVE-2026-29146 suppress

Padding Oracle vulnerability in Apache Tomcat's EncryptInterceptor with default configuration.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.0.0-M1 through 10.1.52, from 9.0.13 through 9..115, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109.

Users are recommended to upgrade to version 11.0.19, 10.1.53 and 9.0.116, which fixes the issue.

CWE-642 External Control of Critical State Data, CWE-1240 Use of a Cryptographic Primitive with a Risky Implementation, CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.116
- ...

CVE-2026-34487 suppress

Insertion of Sensitive Information into Log File vulnerability in the cloud membership for clustering component of Apache Tomcat exposed the Kubernetes bearer token.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.20, from 10.1.0-M1 through 10.1.53, from 9.0.13 through 9.0.116.

Users are recommended to upgrade to version 11.0.21, 10.1.54 or 9.0.117, which fix the issue.

CWE-532 Insertion of Sensitive Information into Log File

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.13; versions up to (excluding) 9.0.117
- ...

CVE-2026-41284 suppress

Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117.
Older, unsupported versions may also be affected.

Users are recommended to upgrade to version [FIXED_VERSION], which fixes the issue.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-43513 suppress

Improper Handling of Case Sensitivity vulnerability in LockOutRealm in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from

7.0.0 through 7.0.109.
Older unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-65927 suppress

Off-by-one Error vulnerability in Apache Tomcat impacting the [N] flag on the rewrite valves causes rewrite processing to restart at the second rule rather than the first rule.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121 which fix the issue.

CWE-193 Off-by-one Error

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2026-68763 suppress

Uncontrolled Resource Consumption vulnerability in Apache Tomcat via an allocation leak in the HTTP/2 backlog tracking when a stream is reset

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.39 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.59 through 8.5.100. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.59; versions up to (excluding) 9.0.121
- ...

CVE-2025-46701 suppress

Improper Handling of Case Sensitivity vulnerability in Apache Tomcat's GCI servlet allows security constraint bypass of security constraints that apply to the pathInfo component of a URI mapped to the CGI servlet.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.6, from 10.1.0-M1 through 10.1.40, from 9.0.0.M1 through 9.0.104.
The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions

may also be affected.

Users are recommended to upgrade to version 11.0.7, 10.1.41 or 9.0.105, which fixes the issue.

CWE-178 Improper Handling of Case Sensitivity

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.105
- ...

CVE-2026-42498 suppress

Exposure of HTTP Authentication Header to unexpected hosts during WebSocket authentication vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.2 through 9.0.117, from 8.5.24 through 8.5.100, from 7.0.83 through 7.0.109.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118, which fix the issue.

CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

CVE-2026-53404 suppress

Always-Incorrect Control Flow Implementation vulnerability in Apache Tomcat's rewrite valve meant that if the first condition in an OR chain matched, subsequent non-OR conditions were skipped.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-670 Always-Incorrect Control Flow Implementation

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.119
- ...

CVE-2026-55957 suppress

Missing Critical Step in Authentication vulnerability in Apache Tomcat when the JNDIRealm was configured to authenticate binds using GSSAPI allowed attackers to authenticate without provided the correct password.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.4, from 10.1.0-M1 through 10.1.36, from 9.0.0.M1 through 9.0.100, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Users are recommended to upgrade to version 11.0.5, 10.1.37 or 9.0.101, which fixes the issue.

CWE-304 Missing Critical Step in Authentication

CVSSv3:
- Base Score: HIGH (7.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.101
- ...

CVE-2020-9484 suppress

When using Apache Tomcat versions 10.0.0-M1 to 10.0.0-M4, 9.0.0.M1 to 9.0.34, 8.5.0 to 8.5.54 and 7.0.0 to 7.0.103 if a) an attacker is able to control the contents and name of a file on the server; and b) the server is configured to use the PersistenceManager with a FileStore; and c) the PersistenceManager is configured with sessionAttributeValueClassNameFilter="null" (the default unless a SecurityManager is used) or a sufficiently lax filter to allow the attacker provided object to be deserialized; and d) the attacker knows the relative file path from the storage location used by FileStore to the file the attacker has control over; then, using a specifically crafted request, the attacker will be able to trigger remote code execution via deserialization of the file under their control. Note that all of conditions a) to d) must be true for the attack to succeed.

CWE-502 Deserialization of Untrusted Data

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.4)
- Vector: /AV:L/AC:M/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY,VDB_ENTRY
- security@apache.org - MAILING_LIST,MITIGATION,PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY,VDB_ENTRY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.43
- ...

CVE-2021-25329 suppress

The fix for CVE-2020-9484 was incomplete. When using Apache Tomcat 10.0.0-M1 to 10.0.0, 9.0.0.M1 to 9.0.41, 8.5.0 to 8.5.61 or 7.0.0. to 7.0.107 with a configuration edge case that was highly unlikely to be used, the Tomcat instance was still vulnerable to CVE-2020-9494. Note that both the previously published prerequisites for CVE-2020-9484 and the previously published mitigations for CVE-2020-9484 also apply to this issue.

NVD-CWE-noinfo

CVSSv3:
- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.4)
- Vector: /AV:L/AC:M/Au:N/C:P/I:P/A:P

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY

- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.41
- ...

CVE-2026-73180 suppress

Insufficient Session Expiration vulnerability in Apache Tomcat meant that if the session ID for an authenticated HTTP session was changed after a WebSocket connection had been established under that authenticated HTTP session, the WebSokcet session would not be closed as required by the Jakarta WebSocket specification when the HTTP session ended.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.24, from 10.1.0-M1 through 10.1.57, from 9.0.0.M1 through 9.0.120.

The following versions were EOL at the time the CVE was created but are
known to be affected: from 8.5.0 through 8.5.100, from 7.0.43 through 7.0.109. Other unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.25, 10.1.58 or 9.0.121, which fix the issue.

CWE-613 Insufficient Session Expiration

CVSSv3:
- Base Score: MEDIUM (6.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 8.5.0; versions up to (excluding) 9.0.121
- ...

CVE-2021-30640 suppress

A vulnerability in the JNDI Realm of Apache Tomcat allows an attacker to authenticate using variations of a valid user name and/or to bypass some of the protection provided by the LockOut Realm. This issue affects Apache Tomcat 10.0.0-M1 to 10.0.5; 9.0.0.M1 to 9.0.45; 8.5.0 to 8.5.65.

CWE-116 Improper Encoding or Escaping of Output

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.46
- ...

CVE-2025-55668 suppress

Session Fixation vulnerability in Apache Tomcat via rewrite valve.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.7, from 10.1.0-M1 through 10.1.41, from 9.0.0.M1 through 9.0.105.
Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.8, 10.1.42 or 9.0.106, which fix the issue.

CWE-384 Session Fixation

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.106
- ...

CVE-2026-55955 suppress

Improper Authentication vulnerability in Apache Tomcat allowed a replay attack against the EncryptionInterceptor in the cluster component.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.13 through 9.0.18, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109.

Users are recommended to upgrade to version 11.0.23, 10.1.56, 9.0.119, which fixes the issue.

CWE-287 Improper Authentication

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2026-55956 suppress

Improper Authorization vulnerability in Apache Tomcat leads to security constraints specified for the default servlet ignoring any method or method omission configured as part of the constraint.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-285 Improper Authorization

CVSSv3:
- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions up to (excluding) 9.0.119
- ...

CVE-2024-23672 suppress

Denial of Service via incomplete cleanup vulnerability in Apache Tomcat. It was possible for WebSocket clients to keep WebSocket connections open leading to increased resource consumption.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M16, from 10.1.0-M1 through 10.1.18, from 9.0.0-M1 through 9.0.85, from 8.5.0 through 8.5.98.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M17, 10.1.19, 9.0.86 or 8.5.99 which fix the issue.

CWE-459 Incomplete Cleanup

CVSSv3:
- Base Score: MEDIUM (6.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.86
- ...

CVE-2022-34305 suppress

In Apache Tomcat 10.1.0-M1 to 10.1.0-M16, 10.0.0-M1 to 10.0.22, 9.0.30 to 9.0.64 and 8.5.50 to 8.5.81 the Form authentication example in the examples web application displayed user provided data without filtering, exposing a XSS vulnerability.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,RELEASE_NOTES,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,RELEASE_NOTES,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.30; versions up to (including) 9.0.64
- ...

CVE-2023-41080 suppress

URL Redirection to Untrusted Site ('Open Redirect') vulnerability in FORM authentication feature Apache Tomcat.This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.0-M10, from 10.1.0-M1 through 10.0.12, from 9.0.0-M1 through 9.0.79 and from 8.5.0 through 8.5.92.
Older, EOL versions may also be affected.

The vulnerability is limited to the ROOT (default) web application.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - ISSUE_TRACKING,PATCH,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - ISSUE_TRACKING,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.79
- ...

CVE-2026-25854 suppress

Occasional URL redirection to untrusted Site ('Open Redirect') vulnerability in Apache Tomcat via the LoadBalancerDrainingValve.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0.M23 through 9.0.115, from 8.5.30 through 8.5.100.
Other, unsupported versions may also be affected

Users are recommended to upgrade to version 11.0.20, 10.1.53 or 9.0.116, which fix the issue.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.116
- ...

CVE-2026-50229 suppress

Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS) vulnerability in the number guess example for Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.22, from 10.1.0-M1 through 10.1.55, from 9.0.0.M1 through 9.0.118, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109. Other versions that have reached end of support may also be affected.

Users are recommended to upgrade to version 11.0.23, 10.1.56 or 9.0.119, which fix the issue.

CWE-80 Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS)

CVSSv3:
- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.119
- ...

CVE-2021-24122 suppress

When serving resources from a network location using the NTFS file system, Apache Tomcat versions 10.0.0-M1 to 10.0.0-M9, 9.0.0.M1 to 9.0.39, 8.5.0 to 8.5.59 and 7.0.0 to 7.0.106 were susceptible to JSP source code disclosure in some configurations. The root cause was the unexpected behaviour of the JRE API File.getCanonicalPath() which in turn was caused by the inconsistent behaviour of the Windows API (FindFirstFileW) in some circumstances.

CWE-706 Use of Incorrectly-Resolved Name or Reference, CWE-200 Exposure of Sensitive Information to an Unauthorized Actor

CVSSv3:
- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.3)
- Vector: /AV:N/AC:M/Au:N/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (including) 9.0.39
- ...

CVE-2021-33037 suppress

Apache Tomcat 10.0.0-M1 to 10.0.6, 9.0.0.M1 to 9.0.46 and 8.5.0 to 8.5.66 did not correctly parse the HTTP transfer-encoding request header in some circumstances leading to the possibility to request smuggling when used with a reverse proxy. Specifically: - Tomcat incorrectly ignored the transfer encoding header if the client declared it would only accept an HTTP/1.0 response; - Tomcat honoured the identify encoding; and - Tomcat did not ensure that, if present, the chunked encoding was the final encoding.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.0)
- Vector: /AV:N/AC:L/Au:N/C:N/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (excluding) 9.0.0; versions up to (including) 9.0.46
- ...

CVE-2023-42795 suppress

Incomplete Cleanup vulnerability in Apache Tomcat.When recycling various internal objects in Apache Tomcat from 11.0.0-M1 through 11.0.0-M11, from 10.1.0-M1 through 10.1.13, from 9.0.0-M1 through 9.0.80 and from 8.5.0 through 8.5.93, an error could
cause Tomcat to skip some parts of the recycling process leading to
information leaking from the current request/response to the next.
Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M12 onwards, 10.1.14 onwards, 9.0.81 onwards or 8.5.94 onwards, which fixes the issue.

CWE-459 Incomplete Cleanup

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY

- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.81
- ...

CVE-2023-45648 suppress

Improper Input Validation vulnerability in Apache Tomcat.Tomcat from 11.0.0-M1 through 11.0.0-M11, from 10.1.0-M1 through 10.1.13, from 9.0.0-M1 through 9.0.81 and from 8.5.0 through 8.5.93 did not correctly parse HTTP trailer headers. A specially crafted, invalid trailer header could cause Tomcat to treat a single request as multiple requests leading to the possibility of request smuggling when behind a reverse proxy.

Older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.0-M12 onwards, 10.1.14 onwards, 9.0.81 onwards or 8.5.94 onwards, which fix the issue.

CWE-20 Improper Input Validation, NVD-CWE-Other

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.81
- ...

CVE-2024-21733 suppress

Generation of Error Message Containing Sensitive Information vulnerability in Apache Tomcat.This issue affects Apache Tomcat: from 8.5.7 through 8.5.63, from 9.0.0-M11 through 9.0.43. Other, EOL versions may also be affected.

Users are recommended to upgrade to version 8.5.64 onwards or 9.0.44 onwards, which contain a fix for the issue.

CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.44
- ...

CVE-2024-54677 suppress

Uncontrolled Resource Consumption vulnerability in the examples web application provided with Apache Tomcat leads to denial of service.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.1, from 10.1.0-M1 through 10.1.33, from 9.0.0.M1 through 9.9.97.
The following versions were EOL at the time the CVE was created but are known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.

Users are recommended to upgrade to version 11.0.2, 10.1.34 or 9.0.98, which fixes the issue.

CWE-400 Uncontrolled Resource Consumption

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L/E:3.9/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.98
- ...

CVE-2025-61795 suppress

Improper Resource Shutdown or Release vulnerability in Apache Tomcat.

If an error occurred (including exceeding limits) during the processing of a multipart upload, temporary copies of the uploaded parts written to disc were not cleaned up immediately but left for the garbage collection process to delete. Depending on JVM settings, application memory usage and application load, it was possible that space for the temporary copies of uploaded parts would be filled faster than GC cleared it, leading to a DoS.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.11, from 10.1.0-M1 through 10.1.46, from 9.0.0.M1 through 9.0.109.

The following versions were EOL at the time the CVE was created but are
known to be affected: 8.5.0 though 8.5.100. Other, older, EOL versions may also be affected.
Users are recommended to upgrade to version 11.0.12 or later, 10.1.47 or later or 9.0.110 or later which fixes the issue.

CWE-404 Improper Resource Shutdown or Release

CVSSv3:
- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H/E:1.6/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.110
- ...

CVE-2019-17569 suppress

The refactoring present in Apache Tomcat 9.0.28 to 9.0.30, 8.5.48 to 8.5.50 and 7.0.98 to 7.0.99 introduced a regression. The result of the regression was that invalid Transfer-Encoding headers were incorrectly processed leading to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.28; versions up to (including) 9.0.30
- ...

CVE-2020-1935 suppress

In Apache Tomcat 9.0.0.M1 to 9.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99 the HTTP header parsing code used an approach to end-of-line parsing that allowed some invalid HTTP headers to be parsed as valid. This led to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:
- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (5.8)
- Vector: /AV:N/AC:M/Au:N/C:P/I:P/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY

- security@apache.org - BROKEN_LINK,MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.30
- ...

CVE-2020-13943 suppress

If an HTTP/2 client connecting to Apache Tomcat 10.0.0-M1 to 10.0.0-M7, 9.0.0.M1 to 9.0.37 or 8.5.0 to 8.5.57 exceeded the agreed maximum number of concurrent streams for a connection (in violation of the HTTP/2 protocol), it was possible that a subsequent request made on that connection could contain HTTP headers - including HTTP/2 pseudo headers - from a previous request rather than the intended headers. This could lead to users seeing responses for unexpected resources.

NVD-CWE-noinfo

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

CVSSv2:
- Base Score: MEDIUM (4.0)
- Vector: /AV:N/AC:L/Au:S/C:P/I:N/A:N

References:
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - VENDOR_ADVISORY
- security@apache.org - BROKEN_LINK
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - PATCH,THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY
- security@apache.org - VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:9.0.30:*:*:*:*:*:*:*
- ...

CVE-2023-28708 suppress

When using the RemoteIpFilter with requests received from a reverse proxy via HTTP that include the X-Forwarded-Proto header set to https, session cookies created by Apache Tomcat 11.0.0-M1 to 11.0.0.-M2, 10.1.0-M1 to 10.1.5, 9.0.0-M1 to 9.0.71 and 8.5.0 to 8.5.85 did not include the secure attribute. This could result in the user agent transmitting the session cookie over an insecure channel.

Older, EOL versions may also be affected.

CWE-523 Unprotected Transport of Credentials

CVSSv3:
- Base Score: MEDIUM (4.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N/E:2.8/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,PATCH,VENDOR_ADVISORY
- security@apache.org - MAILING_LIST,PATCH,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (excluding) 9.0.0; versions up to (excluding) 9.0.72
- ...

CVE-2021-43980 suppress

The simplified implementation of blocking reads and writes introduced in Tomcat 10 and back-ported to Tomcat 9.0.47 onwards exposed a long standing (but extremely hard to trigger) concurrency bug in Apache Tomcat 10.1.0 to 10.1.0-M12, 10.0.0-M1 to 10.0.18, 9.0.0-M1 to 9.0.60 and 8.5.0 to 8.5.77 that could cause client connections to share an Http11Processor instance resulting in responses, or part responses, to be received by the wrong client.

CWE-362 Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY
- security@apache.org - THIRD_PARTY_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (including) 9.0.60
- ...

CVE-2026-24733 suppress

Improper Input Validation vulnerability in Apache Tomcat.

Tomcat did not limit HTTP/0.9 requests to the GET method. If a security constraint was configured to allow HEAD requests to a URI but deny GET requests, the user could bypass that constraint on GET requests by sending a (specification invalid) HEAD request using HTTP/0.9.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.14, from 10.1.0-M1 through 10.1.49, from 9.0.0.M1 through 9.0.112.

Older, EOL versions are also affected.

Users are recommended to upgrade to version 11.0.15 or later, 10.1.50 or later or 9.0.113 or later, which fixes the issue.

CWE-20 Improper Input Validation, NVD-CWE-noinfo

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N/E:2.2/RC:R/MAV:A

References:
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.1; versions up to (excluding) 9.0.113
- ...

CVE-2026-43514 suppress

Observable Timing Discrepancy vulnerability when comparing AJP secret in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.21, from 10.1.0-M1 through 10.1.54, from 9.0.0.M1 through 9.0.117, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.
Older unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.22, 10.1.55 or 9.0.118 which fix the issue.

CWE-208 Observable Timing Discrepancy

CVSSv3:
- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

References:
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- security@apache.org - MAILING_LIST,VENDOR_ADVISORY

Vulnerable Software & Versions: (show all)

- cpe:2.3:a:apache:tomcat:*:*:*:*:*:*:*:* versions from (including) 9.0.0; versions up to (excluding) 9.0.118
- ...

This report contains data retrieved from the National Vulnerability Database.
This report may contain data retrieved from the CISA Known Exploited Vulnerability Catalog.
This report may contain data retrieved from the Github Advisory Database (via NPM Audit API).
This report may contain data retrieved from RetireJS.
This report may contain data retrieved from the Sonatype OSS Index.